NEOLABS

SECURITY LABS · SOC LEVEL 1

SOC Level 1 Complete Toolkit

Analyst handbook, Wazuh guide, templates, references and guided lab

Version: week1-prod-48

Publication date: 2026-08-12

Classification: Student Training Material

Contents

Source: docs/secops-foundations/01-security-operations-foundations.md

Module 1 — Security Operations, SOC Models and Analyst Roles

> **NeoLabs SOC Level 1 principle:** A dashboard can display security information, but a Security Operations Center is the people, processes, evidence, technology and authority used to make and act on security decisions.

Module version: 0.2-draft
Review baseline: 1 August 2026
Expected study time: 3–4 hours

Learning objectives

By the end of this module, a learner should be able to:

- define Security Operations and explain why a SOC is more than a room or SIEM dashboard;
- describe internal, outsourced, hybrid and virtual SOC models;
- distinguish the typical responsibilities of SOC Level 1, Level 2 and Level 3 personnel;
- use the terms log, event, alert, case, finding, incident, evidence, IOC and IOA correctly;
- distinguish severity, priority, confidence and business impact;
- explain the boundary between investigation, escalation and authorised response;
- describe a normal SOC shift from handover to closure.

---

1. What Security Operations means

Professional definition

Security Operations, commonly shortened to **SecOps**, is the continuing organisational capability used to monitor technology environments, identify suspicious or harmful activity, investigate security-relevant events, coordinate response and improve defensive controls.

SecOps is continuous because organisational systems continue generating activity outside normal office hours. Even a small organisation that does not operate a 24-hour staffed SOC still needs processes for receiving alerts, deciding urgency and contacting someone who is authorised to act.

Plain-language explanation

SecOps is the part of cybersecurity that asks:

1. What is happening in our systems right now?
2. Is any of it unsafe, unauthorised or unusual enough to investigate?
3. What evidence supports that conclusion?
4. Who needs to know or act?
5. What should change so the same problem is detected or prevented more effectively next time?

A SOC supports those questions with analysts, procedures, logging, SIEM or XDR platforms, endpoint tools, network data, cloud audit trails, ticketing systems, communication channels and management authority.

People, process and technology

Element	What it contains	Why it matters
People	Analysts, incident responders, threat hunters, engineers, IT staff, legal, management and system owners	Tools cannot decide business impact or authorise every response action
Process	Triage steps, severity definitions, escalation paths, playbooks, evidence handling and reporting	A repeatable process reduces inconsistent decisions during pressure
Technology	SIEM, Wazuh, endpoint protection, firewalls, cloud logs, threat intelligence and case systems	Technology collects and organises evidence at a scale people cannot review manually

A mature SOC keeps these elements aligned. Buying a SIEM without staffing, useful logs or escalation procedures creates an expensive dashboard rather than an effective security operation.

---

2. What a Security Operations Center is

A **Security Operations Center (SOC)** is the team and operating structure that centralises security monitoring and incident-handling activities. “Center” does not require a physical room. A distributed team can operate a virtual SOC if it has defined responsibilities, secure tools, reliable communication and an established chain of authority.

Core SOC functions

A SOC commonly performs some combination of the following:

- monitoring alert queues and important data sources;
- validating that required telemetry is arriving;

- triaging and classifying alerts;
- investigating activity across identities, hosts, applications, networks and cloud resources;
- documenting evidence and maintaining case records;
- escalating confirmed or unresolved risk;
- coordinating containment and recovery with authorised teams;
- tuning detections and reducing avoidable noise;
- measuring coverage, workload and response performance;
- preserving lessons from incidents and near misses.

SOC is not the same as IT support

IT support and SecOps often cooperate, but their primary questions differ.

IT support question	SecOps question
Why can the user not sign in?	Is the failed sign-in activity normal, accidental or hostile?
Why is the server slow?	Is the slowdown associated with scanning, resource abuse or unauthorised execution?
How do we restore the service?	What evidence must be preserved before restoration, and could recovery reintroduce the threat?
Which update fixes the error?	Does the missing update expose a vulnerability that changes incident priority?

One event can require both teams. A locked account might be a normal support issue, a password attack or both.

---

3. Common SOC operating models

3.1 Internal SOC

An **internal SOC** is operated by the organisation’s own employees. It usually has deeper knowledge of the organisation’s systems, business processes and approved administrative behaviour.

Advantages

- strong access to internal context and system owners;
- direct control over tooling and procedures;
- easier alignment with organisational priorities.

Challenges

- staffing a 24-hour operation can be expensive;
- specialist expertise may be difficult to recruit;
- small teams can experience alert fatigue and coverage gaps.

3.2 Managed Security Service Provider or Managed SOC

A **Managed Security Service Provider (MSSP)** or managed SOC monitors systems for multiple customer organisations under a service agreement.

Advantages

- broader staffing coverage;
- access to established platforms and specialist personnel;
- useful for organisations that cannot build a complete internal SOC.

Challenges

- analysts may initially lack business context;
- customer and provider responsibilities must be clearly divided;
- escalation and evidence-sharing delays can affect response.

3.3 Hybrid SOC

A **hybrid SOC** combines internal capability with an external provider. For example, a provider may monitor overnight alerts while internal staff handle daytime investigations and response decisions.

This model works only when ownership is explicit. An alert should never remain unresolved because both parties assumed the other was responsible.

3.4 Virtual or distributed SOC

A **virtual SOC** operates across different locations without requiring one physical room. It still needs controlled access, shift handover, case tracking, secure communications and an on-call structure.

3.5 Follow-the-sun model

Large organisations may hand monitoring between teams in different time zones. This provides continuous coverage but makes clear case notes and handover quality essential.

---

4. SOC roles and tier boundaries

Role names differ between organisations. “Level 1” does not always describe exactly the same permissions or responsibilities. The VCC programme uses the following learning model.

4.1 SOC Level 1 — monitoring and triage

A Level 1 analyst is commonly the first human reviewer of an alert. The analyst’s job is not to prove every incident alone. It is to perform a reliable first investigation and make the next decision defensible.

Typical responsibilities include:

- review the alert and underlying raw event;
- verify the source, time and affected entity;
- determine whether expected telemetry is present;
- collect basic context about the account, host, application or resource;
- search a reasonable time window for related activity;
- distinguish obvious benign causes from unresolved or suspicious activity;
- classify the alert using the organisation’s definitions;
- document facts, interpretation, uncertainty and queries performed;
- escalate when scope, impact, permissions or complexity exceed Level 1 authority.

In the VCC programme, interns may recommend an action but do not perform unauthorised containment against lab infrastructure.

4.2 SOC Level 2 — deeper investigation and coordinated response

Level 2 analysts usually handle escalated cases requiring broader correlation or response coordination. Activities may include:

- reconstructing a detailed timeline across several data sources;
- scoping affected identities and assets;
- validating whether an attack succeeded;
- coordinating approved containment with IT, cloud or application teams;
- collecting additional forensic evidence;
- determining root cause and likely entry path;
- updating stakeholders and case severity;
- identifying detection gaps.

4.3 SOC Level 3 — threat hunting, advanced analysis and detection engineering

Level 3 titles can include threat hunter, senior analyst, malware analyst or detection engineer. Typical work may include:

- hypothesis-driven hunting beyond existing alerts;

- advanced endpoint, network or malware analysis;
- researching adversary behaviour;
- creating and validating new detections;
- leading complex incidents;
- improving playbooks and architecture;
- mentoring junior analysts.

4.4 Supporting roles

A SOC depends on people outside the tier structure:

- **SOC manager:** staffing, process ownership, metrics and escalation authority;
- **SIEM/platform engineer:** ingestion pipelines, parsers, storage, upgrades and platform health;
- **detection engineer:** threat hypotheses, analytics, validation and tuning;
- **incident commander:** coordinates a major incident and keeps decision-making organised;
- **forensic examiner:** acquires and analyses evidence using controlled methods;
- **threat intelligence analyst:** provides adversary, campaign and indicator context;
- **system or application owner:** explains expected behaviour and business impact;
- **legal/privacy/communications:** advises on obligations and external communication.

---

5. Core terminology

5.1 Log

A **log** is a stored record produced by a system, application, service, device or security tool.

Example:

```
2026-08-01T09:14:21Z web01 sshd[24109]: Failed password for invalid user admin from 203.0.113.44 port 44218 ssh2
```

The record states that an SSH authentication attempt failed. It does not identify the human behind the source address and does not prove compromise.

5.2 Event

An **event** is a specific occurrence represented by one or more log records. A successful sign-in, file change, process start or cloud API request can be an event.

5.3 Alert

An **alert** is a notification produced when a rule, analytic, threshold or model decides that an event or sequence deserves analyst attention.

An alert is a lead, not a verdict. A rule can match correctly while the underlying activity remains authorised.

5.4 Case or ticket

A **case** or **ticket** is the organised record of analyst work. It normally stores the alert, affected entities, evidence, timeline, queries, decisions, communications and next actions.

5.5 Finding

A **finding** is a statement supported by analysed evidence.

Weak finding:

> The user was hacked.

Better finding:

> Authentication logs recorded 47 failed sign-ins for `learner-17` from `203.0.113.44`, followed by one successful sign-in from the same source. The account's normal source range is not available, so unauthorised access is suspected but not yet confirmed. Confidence: medium.

5.6 Incident

A **cybersecurity incident** is an occurrence that actually or imminently jeopardises information or systems, violates security policy, or requires coordinated response according to the organisation's definition.

Not every alert becomes an incident. Organisations should document their own declaration criteria.

5.7 Evidence

Evidence is information preserved and interpreted to support or challenge a conclusion. Good evidence records include source, time, collection method, relevant fields and integrity considerations.

A screenshot can support a report, but the underlying event or export is usually stronger because it is searchable and contains more fields.

5.8 Indicator of Compromise and Indicator of Attack

An **Indicator of Compromise (IOC)** is an observable value associated with known or suspected malicious activity, such as a file hash, domain, IP address or registry path.

An **Indicator of Attack (IOA)** focuses on behaviour that may show an attack in progress, such as repeated credential guessing followed by unusual access.

IOC caution: addresses, domains and hashes can be shared, reassigned, spoofed or used in benign contexts. An IOC match requires validation.

---

6. Severity, priority, impact and confidence

These terms are related but not interchangeable.

Severity

Severity describes the potential or confirmed seriousness of the security condition. An organisation may calculate severity from technical impact, affected asset criticality, data sensitivity and scope.

Priority

Priority determines the order and urgency of work. A technically severe event may receive lower immediate priority if it is fully contained, while a medium-severity alert affecting an executive account may require immediate review.

Business impact

Business impact describes consequences to operations, finances, safety, legal obligations, reputation or customers.

Confidence

Confidence describes how strongly available evidence supports the current conclusion.

Confidence	Appropriate use
Low	Limited evidence, major visibility gaps or several plausible explanations
Medium	Multiple supporting observations but missing confirmation or context
High	Strong corroborated evidence with few reasonable alternatives

Confidence is not the same as severity. A potentially critical incident can begin with low-confidence evidence and still require urgent escalation.

Worked example

An alert reports a new administrator account on a test server.

- **Potential severity:** High, because unauthorised administrator creation can enable control of the host.
- **Current confidence:** Medium, because the creation event is confirmed but change approval has not been checked.
- **Priority:** High until the system owner confirms whether the account was expected.
- **Impact:** Unknown; no activity by the new account has yet been identified.

---

7. A normal SOC shift

7.1 Handover

The incoming analyst reviews:

- open high-priority cases;
- pending owner responses;
- known maintenance windows;
- platform or data-source outages;
- threat advisories relevant to monitored systems;
- actions that require follow-up.

A good handover states what is known, what remains uncertain and the next action. “Still investigating” is not enough.

7.2 Platform and queue health

Before trusting the alert queue, the analyst checks that the monitoring system is healthy:

- are agents or feeds connected?
- are event volumes within an expected range?
- are timestamps current?
- are parsing fields populated?
- are index or storage errors present?

No alerts can mean no threats, a quiet environment or a broken telemetry pipeline.

7.3 Alert triage

The analyst opens an alert, reviews raw evidence, enriches context, searches related events and decides whether to close, continue or escalate.

7.4 Case documentation

Work is recorded during the investigation, not reconstructed from memory at the end. Queries, time ranges and important negative results should be documented.

7.5 Escalation and communication

The analyst follows the defined escalation route, supplies relevant evidence and avoids overstating conclusions.

7.6 Shift closure

Before handover, the analyst updates open cases, identifies deadlines and records platform issues. Unwritten knowledge is easily lost between shifts.

---

8. Worked scenario — failed sign-ins followed by success

Alert summary

```
Detection: Repeated authentication failures followed by success
Account: svc-backup
Destination: app-pod-03
First failure: 2026-08-01T09:14:21Z
Success: 2026-08-01T09:18:07Z
Source: 203.0.113.44
```

Initial questions

1. Is `svc-backup` expected to sign in interactively?
2. Is the source address expected for the service?
3. What authentication method was used?
4. What happened after the success?
5. Did the same source target other accounts?
6. Was there a maintenance or deployment window?
7. Are the timestamps and source fields trustworthy?

Observation, interpretation and conclusion

Observation: The monitored authentication source recorded 19 failures for `svc-backup` from `203.0.113.44`, followed by one successful authentication from the same source.

Interpretation: A failure-to-success sequence can occur during password guessing, but it can also result from a stored credential being corrected or an automation retrying after a secret rotation.

Current conclusion: Suspicious authentication requiring escalation unless approved maintenance explains the sequence. Confidence: medium.

Next evidence: Post-authentication activity, deployment records, service owner confirmation and other accounts targeted by the source.

---

9. Common beginner mistakes

Mistake 1 — treating the alert title as evidence

The title is a summary produced by detection logic. Always inspect the records that caused it.

Mistake 2 — assuming unusual means malicious

An anomaly differs from the baseline. It becomes suspicious or malicious only when context and evidence support that judgment.

Mistake 3 — using “false positive” for every benign alert

A rule may correctly detect behaviour that is real but authorised. Some teams call this a **benign positive** rather than a false positive. Use the organisation’s definitions consistently.

Mistake 4 — escalating without a useful handoff

“Please investigate” transfers work but not understanding. Include the trigger, affected entities, timeline, searches, evidence, classification and unresolved questions.

Mistake 5 — taking response actions outside authority

Disabling accounts, blocking addresses or isolating systems can affect operations and evidence. Follow the authorised process.

Mistake 6 — ignoring telemetry health

Missing data is not evidence that nothing happened.

---

10. Guided exercise

For each statement, identify whether it is an observation, interpretation or conclusion.

1. `Event ID 4625 recorded a failed network logon for account student03 from 203.0.113.80.`
2. `The source address is outside the account's documented normal range.`
3. `The activity is suspicious and should be escalated for possible password guessing.`
4. `No process-creation events were found in the available five-minute window.`
5. `Endpoint process auditing may be disabled, so the absence of process events does not rule out execution.`

Suggested discussion:

- Statements 1 and 4 are observations.
- Statements 2 and 5 are interpretations based on context or visibility.
- Statement 3 is a conclusion and action decision.

---

11. Review questions

1. Why is a SOC more than a SIEM dashboard?
2. What is the practical difference between an event and an alert?
3. What should a Level 1 analyst normally include in an escalation?
4. Why can severity be high while confidence remains low?
5. Give one example of an IOC and one limitation of IOC-based decisions.
6. What does a quiet alert queue fail to prove?
7. Explain the difference between observation, interpretation and conclusion.
8. When should a Level 1 analyst stop investigating and escalate?

References

- NIST SP 800-61 Rev. 3, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management*.
- NIST SP 800-92, *Guide to Computer Security Log Management*.
- NIST SP 800-92 Rev. 1 Initial Public Draft, *Cybersecurity Log Management Planning Guide*.
- MITRE ATT&CK v19.1.
- Wazuh official documentation, architecture and data-analysis sections.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: docs/secops-foundations/02-alert-triage-evidence-and-escalation.md

Module 2 — Alert Triage, Evidence and Escalation

> **NeoLabs SOC Level 1 principle:** Triage is a disciplined decision process. It is not a race to close alerts and it is not a requirement to solve every incident alone.

Module version: 0.2-draft
Review baseline: 1 August 2026
Expected study time: 4–5 hours

Learning objectives

By the end of this module, a learner should be able to:

- explain the purpose and limits of SOC Level 1 triage;
- apply a repeatable alert-review workflow;
- verify the evidence behind an alert before accepting its title;
- identify affected entities, scope, time window and data-source health;
- distinguish true positive, benign positive, false positive and insufficient evidence;
- record queries, negative results, assumptions and confidence;
- prepare a useful escalation package;
- recognise stop conditions that require immediate escalation.

---

1. What triage means

In medicine, triage determines who needs attention first. In a SOC, **alert triage** is the initial process used to decide what an alert represents, how urgent it is, whether more investigation is needed and who should handle the next action.

Triage answers four practical questions:

1. **Is the alert based on valid and trustworthy data?**
2. **What entity and activity are involved?**
3. **How concerning is the activity in context?**
4. **Should the alert be closed, monitored, investigated further or escalated?**

A Level 1 analyst should reach the best supported decision possible within the allotted time and authority. Spending hours on a case that clearly requires a higher tier can delay response.

2. The NeoLabs L1 triage workflow

Use the following sequence unless a playbook requires a different order.

```
Receive alert
  → verify source and raw event
  → establish time, identity, asset and action
  → validate telemetry health
  → gather immediate context
  → search related activity
  → consider benign explanations
  → classify and assign confidence
  → document and close or escalate
```

Step 1 — Read the alert without trusting the conclusion

Record:

- alert name and identifier;
- creation time;
- detection or rule identifier;
- severity assigned by the tool;
- data source;
- affected user, host, application, IP, file or cloud resource;
- the raw event or events that triggered it.

The alert severity is input to the investigation, not the final decision.

Step 2 — Verify the raw evidence

Ask:

- does the raw record exist?
- did the expected parser or decoder extract the fields correctly?
- is the timestamp event time or ingest time?
- is the source field the original client, a proxy or a collector?
- is the alert based on one record, a threshold or a sequence?
- could duplicate ingestion have inflated the count?

Example:

An alert says “20 failed SSH logins.” Inspection reveals the same event was ingested twice by two collectors, meaning there were 10 attempts, not 20. The activity may still be suspicious, but the analyst must correct the scope.

Step 3 — Identify the entities

An **entity** is something involved in the activity and useful for correlation.

Common entities include:

- user account or service account;
- source and destination IP address;
- hostname, device ID, agent ID or cloud resource;
- process image, PID, Process GUID or command line;
- file path and hash;
- URL, domain, request ID or session ID;
- role, API key identifier or cloud account;
- pod identifier in the VCC lab.

Record stable identifiers where available. A display name may change; a SID, ARN, agent ID or request ID can be more reliable.

Step 4 — Establish the investigation window

Start with a narrow window around the alert, then expand only when evidence requires it.

Example approach:

- 5 minutes before and after for a single process or web request;
- 15–30 minutes for an authentication sequence;
- several hours for account takeover or cloud configuration changes;
- days for low-frequency persistence or slow credential abuse.

Do not assume records are perfectly ordered. Clock drift, delayed forwarding and different time zones can move events outside the expected sequence.

Step 5 — Validate telemetry health

Before interpreting missing evidence, determine whether the source could have produced and delivered it.

Check:

- agent or feed connection state;
- last event time;
- normal event volume;
- audit policy or log configuration;
- parser/decoder success;
- index availability and retention;
- system clock and time zone.

Important distinction:

- **No evidence found** means the search did not return the event.
- **Evidence that no activity occurred** requires a source that reliably records the activity and was functioning during the relevant period.

Step 6 — Gather context

Useful context can include:

- asset criticality and owner;
- account role and normal function;
- normal source locations or peer group;
- maintenance and deployment windows;
- approved vulnerability scanning;
- known automation or scheduled tasks;
- threat-intelligence matches;
- recent password resets or configuration changes;
- prior alerts involving the same entity.

Context should explain behaviour, not automatically excuse it. “It is an administrator account” can increase risk rather than make unusual activity harmless.

Step 7 — Search for related activity

Good pivots include:

- same user across other hosts;
- same source IP against other users;
- same host before and after the alert;
- process parent and child relationships;
- file hash or path across endpoints;
- request ID across proxy, application and database logs;
- cloud access-key or role session across API events;
- same pod and correlation ID across VCC telemetry.

Record both the query and time range. “Checked logs” is not reproducible.

Step 8 — Consider alternative explanations

A strong analyst actively tests benign and malicious explanations.

For repeated login failures, alternatives may include:

- password guessing;
- a user typing an old password;
- a service using an expired secret;
- a vulnerability scanner;
- a disconnected system repeatedly retrying;
- an attacker testing leaked credentials.

The goal is not to invent excuses. It is to avoid closing on the first plausible story.

Step 9 — Classify and assign confidence

Use the programme’s approved categories. A practical training model is:

Classification	Meaning
False positive	Detection logic or parsing produced an incorrect match
Benign positive	Detection correctly identified the behaviour, but the activity was authorised or expected
Suspicious	Evidence justifies concern, but malicious activity is not confirmed
Confirmed incident	Evidence supports unauthorised or harmful activity requiring coordinated response
Insufficient evidence	Available telemetry or context cannot support a reliable classification
Data-quality issue	The primary problem is missing, duplicated, delayed or incorrectly parsed telemetry

Add a confidence statement and explain why.

Step 10 — Document and act

A case record should allow another analyst to continue without repeating all work.

At minimum include:

- alert and affected entities;
- event and ingest times;
- observed facts;
- queries and time ranges;
- correlated evidence;
- relevant negative findings;
- alternative explanations considered;
- current classification and confidence;
- recommended next action;
- reason for closure or escalation.

3. What evidence proves, suggests and cannot prove

Example 1 — Firewall allow record

```
{
  "event_time": "2026-08-01T10:02:44Z",
  "action": "ACCEPT",
  "src_ip": "203.0.113.9",
  "src_port": 53120,
  "dst_ip": "10.20.3.15",
  "dst_port": 443,
  "protocol": "TCP"
}
```

Proves: The firewall recorded an allowed flow with those observed network fields.

Suggests: A connection may have been established between the source and destination.

Does not prove: Which human initiated it, what application data was exchanged, whether authentication succeeded or whether exploitation occurred.

Example 2 — HTTP 200 response

```
203.0.113.44 - - [01/Aug/2026:10:06:22 +0000] "GET /api/profile/204 HTTP/1.1" 200 894
```

Proves: The web server returned HTTP status 200 for the logged request.

Suggests: The route processed successfully from the server’s perspective.

Does not prove: The requester was authorised to access profile 204, that the response contained sensitive data or that the client received the full response.

Example 3 — Antivirus detection

An antivirus alert proves that the product identified content or behaviour matching its detection logic. It does not automatically prove successful execution, persistence or impact. Quarantine status, process telemetry, file origin and surrounding activity are still required.

---

4. Alert dispositions in detail

False positive

Use this when the detection itself is wrong or misleading.

Examples:

- a parser placed the destination IP in the source field;
- a rule matched a harmless string because it lacked boundaries;
- duplicate records caused a threshold to trigger incorrectly;
- a test record was accidentally classified as production activity.

Document the detection problem so it can be tuned.

Benign positive

The rule correctly detected the behaviour, but context shows it was authorised.

Example:

A rule detects a new scheduled task. Change records confirm an approved backup agent installed it, the binary is signed, the path is expected and the timing matches the deployment window.

The event is not a false positive because the scheduled task genuinely existed.

Suspicious activity

The evidence is concerning but incomplete.

Example:

A service account logged in interactively from a new source and launched a shell, but account ownership and maintenance context have not been confirmed.

Confirmed incident

The available evidence satisfies the organisation’s incident criteria.

Example:

An unauthorised account successfully accessed a protected resource, changed configuration and attempted to remove audit records. Multiple sources corroborate the sequence.

Insufficient evidence

Use this when visibility gaps prevent a defensible result. Do not disguise uncertainty as a benign closure.

Example:

A suspected process-execution alert cannot be validated because process auditing was disabled and the endpoint was rebuilt before evidence collection.

Data-quality issue

Sometimes the incident is the monitoring failure itself.

Examples:

- a critical application stopped sending authentication logs;
- event times are shifted by two hours;
- a new schema caused decoder fields to become empty;
- records are being ingested twice.

---

5. Escalation

5.1 Why escalation exists

Escalation transfers a case to someone with additional authority, expertise, tooling or time. It should reduce delay, not merely move responsibility.

5.2 Common escalation triggers

Escalate when:

- activity may affect a critical asset or privileged identity;
- a successful compromise is possible or confirmed;
- scope appears larger than one user or host;
- containment may be required;
- malware, persistence or lateral movement is suspected;
- sensitive or regulated data may be involved;
- evidence collection requires tools or permissions the analyst lacks;
- the alert matches a mandatory playbook trigger;
- the investigation exceeds the approved Level 1 time limit;
- telemetry gaps prevent a safe closure;
- the analyst is uncertain whether an action is authorised.

5.3 Immediate stop conditions

In the VCC environment, stop and escalate immediately if:

- a task appears to require access outside the assigned student-facing interfaces;
- credentials, private keys or production-looking data appear in evidence;
- telemetry appears to come from another pod;
- a student can change configuration and view another pod’s events;
- a requested action could disrupt the lab host or other students;
- the scenario no longer matches the written scope.

5.4 Escalation package

A useful escalation contains:

```
Case title:
Alert ID and detection:
Current severity / priority:
Affected entities:
Earliest and latest relevant event time:
Observed facts:
Queries and sources reviewed:
Timeline summary:
Current classification:
Confidence and reason:
Alternative explanations considered:
Business or lab impact:
Actions already taken:
Recommended next action:
Unresolved questions:
```

Weak escalation

> Suspicious login. Please check.

Stronger escalation

> Wazuh alert `AUTH-SEQ-0142` identified 19 failed logins and one success for `svc-backup` on `pod-03-app` from `203.0.113.44` between 09:14:21Z and 09:18:07Z. The account is labelled as a service identity, and interactive use is not documented in the available profile. I searched the same source across all assigned pod authentication records for ±30 minutes and found failures against two additional accounts. No approved maintenance note is attached. Post-login process telemetry is unavailable because that source stopped reporting at 09:16Z. Classification: suspicious; confidence medium. Escalation requested for account-owner validation and telemetry-gap review.

---

6. Query and evidence journal

Every meaningful search should be reproducible.

Time run	Data source	Query or filter	Time range	Result summary	Next pivot
10:20Z	Wazuh alerts	`data.user: "svc-backup"`	09:00–10:00Z	20 authentication records	Search same source IP
10:23Z	Wazuh alerts	`data.srcip: "203.0.113.44"`	08:45–10:15Z	Three accounts targeted	Check success and post-login events
10:27Z	Endpoint events	host `pod-03-app`	09:15–09:30Z	No records after 09:16Z	Validate source health

A negative result matters only when the data source and query were capable of finding the activity.

---

7. Worked investigation — possible web-account takeover

Alert

```
{
  "rule": "Successful login after repeated failures",
  "user": "student17",
  "src_ip": "198.51.100.73",
  "destination": "vcc-pod-02",
  "failure_count": 12,
  "success_time": "2026-08-01T11:42:08Z",
  "risk": "high"
}
```

Step 1 — Validate

The analyst confirms 12 distinct failed events and one success. No duplicates are present. The source IP field came from the application after trusted-proxy processing.

Step 2 — Context

The user normally signs in from a different example source range. No scheduled test or password-reset activity is documented.

Step 3 — Correlation

The analyst searches the session ID created by the success and finds:

- profile viewed;
- email-change page opened;
- password reset requested;
- no confirmed profile change;

- session revoked five minutes later by the scenario controller.

Step 4 — Interpretation

The sequence is consistent with attempted account takeover, but the lab record does not identify the actor or prove credentials were obtained through any specific method.

Step 5 — Disposition

Classification: Confirmed synthetic security incident within the assigned VCC scenario.
Confidence: High.
Reason: Successful access from the failure source followed by sensitive account actions, corroborated by session and application records.
Escalation: Provide timeline and affected session to mentor; recommend credential reset and review of other accounts targeted by the source within the scenario.

---

8. Time management in L1 triage

A fixed time limit is organisation-specific. The purpose is to prevent one difficult case from blocking the queue.

A practical approach:

- first 2 minutes: verify alert, source and affected entity;
- next 5–10 minutes: gather immediate context and perform core pivots;
- decision point: close with evidence, continue under a playbook or escalate;
- document throughout.

Do not use a time limit to force a benign answer. If the result remains uncertain, state the uncertainty and escalate appropriately.

---

9. Common mistakes

Searching only alerts

Relevant events may exist in raw or archive data without triggering a rule.

Ignoring time zones

Comparing local application time with UTC cloud time can create a false sequence.

Copying raw logs without analysis

Evidence must be connected to the question. A large dump is not a clear escalation.

Closing because an IOC is not on a threat list

Absence from a list does not make an address or file safe.

Overstating identity

An account name or source IP does not automatically identify the human responsible.

Failing to record negative results

A later analyst needs to know what was searched, where and for what time range.

Recommending destructive action too early

Containment should be proportionate and authorised. Preserve evidence and consider business impact.

---

10. Guided practice

Use the synthetic records in `sample-logs/authentication/` when available.

Prepare:

1. a one-paragraph alert summary;
2. a table of affected entities;
3. three queries and their results;
4. an observation–interpretation–conclusion statement;
5. a classification and confidence level;
6. an escalation package or closure justification.

Do not assume the alert is malicious. Test at least two alternative explanations.

---

11. Review questions

1. Why must an analyst inspect the raw event behind an alert?
2. What is the difference between a false positive and a benign positive?
3. When can a negative search result be treated as meaningful evidence?
4. Name five useful correlation entities.
5. Why should the analyst record time ranges with queries?
6. Give three examples of immediate VCC stop conditions.

7. What information makes an escalation useful to Level 2?
8. Why can a telemetry outage require escalation even when no compromise is confirmed?
9. Classify this statement: “The host stopped reporting after the successful login, so the attacker disabled logging.” What is wrong with it?
10. How should an analyst communicate uncertainty?

References

- NIST SP 800-61 Rev. 3.
- NIST SP 800-92 and SP 800-92 Rev. 1 Initial Public Draft.
- Wazuh official documentation: alert management, event logging, WQL and dashboard navigation.
- MITRE ATT&CK v19.1 Detection Strategies, Analytics and Data Components.
- NeoLabs Log Literacy Manual.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: docs/secops-foundations/03-siem-pipelines-and-log-quality.md

Module 3 — SIEM Pipelines, Data Quality and Detection Context

> **NeoLabs SOC Level 1 principle:** Before trusting a dashboard result, understand how the source activity became a searchable field and which failures could have altered or removed the evidence.

Module version: 0.2-draft
Review baseline: 1 August 2026
Expected study time: 4–6 hours

Learning objectives

By the end of this module, a learner should be able to:

- define SIEM and explain its relationship to log management, detection and case handling;
- describe generation, collection, transport, parsing, normalisation, enrichment, indexing, detection and alerting;
- distinguish raw events, decoded fields, indexed documents and alerts;
- identify common data-quality failures and their investigative effect;
- explain why event time and ingest time can differ;
- recognise schema drift, duplicate ingestion, clock skew and retention gaps;
- validate a telemetry pipeline before concluding that an event did not occur;
- explain the Wazuh manager, indexer and dashboard roles at a beginner-to-intermediate level.

---

1. What a SIEM is

A **Security Information and Event Management (SIEM)** platform centralises security-relevant data, makes it searchable and applies rules or analytics to identify activity that deserves investigation.

A SIEM normally supports four broad capabilities:

1. **Collection:** receive records from endpoints, applications, network devices, identity systems and cloud services.
2. **Organisation:** parse, normalise, enrich, index and retain records.
3. **Detection:** evaluate records or sequences against rules, thresholds and analytics.

4. **Investigation:** provide searches, visualisations, alert queues and links to evidence.

A SIEM does not create visibility that the source never generated. If process auditing is disabled, the SIEM cannot reconstruct every process from nothing. If an application logs only “request failed” without user, route or request ID, later investigation will be limited.

SIEM, XDR and log management

- **Log management** covers the generation, transmission, storage, access and disposal of log data.
- **SIEM** adds security-oriented correlation, detection, investigation and alerting.
- **XDR** generally combines detection and response across several security domains, such as endpoints, identities, cloud and email. Product definitions differ.

For SOC Level 1 work, the important skill is not memorising product categories. It is understanding which source produced the evidence, how it was transformed and what response authority exists.

---

2. The telemetry pipeline

```
System activity
  → log generation
  → collection
  → transport
  → parsing / decoding
  → normalisation
  → enrichment
  → indexing and retention
  → rule or analytic
  → alert
  → investigation and case record
```

Each stage can succeed, fail or change the meaning available to an analyst.

2.1 System activity

Something occurs: a user signs in, a process starts, a file changes, a web request reaches an API or a cloud role performs an action.

The activity itself is not the log. The log is a system’s recorded representation of that activity.

2.2 Log generation

The source must be configured to record the event.

Examples:

- Windows Security auditing records selected authentication and account events.
- Sysmon records configured process, network, DNS, file and registry activity.
- NGINX records requests according to its log format.
- AWS CloudTrail records supported API activity according to trail and event-selector configuration.
- An application records business events only if developers implemented suitable logging.

Generation failure: Auditing is disabled, the event category is excluded or the application never logs the required action.

2.3 Collection

A collector reads the event from the source.

Collection mechanisms include:

- Wazuh agents;
- Windows Event Forwarding;
- syslog;
- API polling;
- cloud object storage;
- file readers;
- container stdout collectors;
- message queues.

Collection failure: The agent is stopped, lacks permission, watches the wrong path or starts after the event occurred.

2.4 Transport

Records move from the source or collector to the analysis platform.

Security considerations include:

- authentication of the sender and receiver;
- encryption in transit;
- buffering when the destination is unavailable;
- duplicate delivery after retries;
- network and proxy paths;
- size or rate limits.

Transport failure: Network interruption, expired certificate, rejected credentials, queue overflow or dropped oversized records.

2.5 Parsing or decoding

Parsing converts raw text or structured records into fields.

Raw example:

```
Aug 01 09:14:21 web01 sshd[24109]: Failed password for invalid user admin from 203.0.113.44 port 44218
ssh2
```

Possible decoded fields:

```
{
  "host": "web01",
  "program": "sshd",
  "process_id": 24109,
  "event_action": "authentication_failure",
  "user": "admin",
  "user_status": "invalid",
  "source_ip": "203.0.113.44",
  "source_port": 44218,
  "protocol": "ssh2"
}
```

Parsing makes searches more reliable, but the raw record should remain available where policy permits.

Parsing failure: The format changes, the decoder matches the wrong pattern or a field contains unexpected characters.

2.6 Normalisation

Normalisation maps similar meanings from different sources to consistent field names and values.

Source-specific field	Normalised idea
`src`, `client_ip`, `sourceIPAddress`	source IP address
`username`, `TargetUserName`, `userIdentity.arn`	acting or targeted identity, with source-specific detail retained
`result`, `status`, HTTP status	outcome, interpreted according to source semantics

Normalisation helps cross-source searches. It must not erase important differences. An AWS role ARN is not identical to a Windows username even if both represent identity.

2.7 Enrichment

Enrichment adds context not present in the original event.

Examples:

- asset owner and criticality;
- approved pod identifier;
- IP reputation or geographic context;
- vulnerability exposure;
- identity role;
- threat-intelligence tags;
- change-window information.

Enrichment can become stale. A system may have changed owner, a cloud address may be reassigned and a threat-intelligence match may be outdated.

2.8 Indexing and retention

An index stores fields in a form designed for search. Field mappings determine whether values behave as exact keywords, analysed text, numbers, dates or IP addresses.

Examples of mapping problems:

- a numeric status stored as text cannot be reliably compared with numeric ranges;
- an IP stored as ordinary text loses IP-aware queries;
- a timestamp stored in an unrecognised format may sort incorrectly;
- a username analysed into tokens may behave differently from an exact keyword field.

Retention determines how long evidence remains searchable or archived. Retention must consider operational need, incident-discovery delay, privacy, regulation, storage cost and evidence requirements.

2.9 Detection

A detection evaluates records or sequences.

Common detection types:

- exact or pattern match;
- threshold within a time window;
- sequence, such as failures followed by success;
- correlation across sources;
- baseline or anomaly comparison;
- threat-intelligence match;
- model or risk score.

A detection should state its data requirements. A rule that depends on command lines cannot work correctly when command-line auditing is disabled.

2.10 Alerting

The platform creates an alert with fields such as rule, severity, entities, evidence links and timestamps.

The alert may summarise several events. Analysts should determine whether the displayed count represents distinct source events, grouped documents or duplicated ingestion.

---

3. Wazuh components in this toolkit

Wazuh manager

The **Wazuh manager** receives and analyses security data. It runs decoders and rules, manages agent-related functions and produces alert records.

In the NeoLabs student deployment, the manager also monitors a local NDJSON file written by the authorised VCC telemetry collector. The collector obtains only the feed issued to that learner’s assigned pod.

Wazuh indexer

The **Wazuh indexer** stores and indexes alert and security data for search and visualisation. It is based on OpenSearch technology.

The indexer should not be exposed publicly in the student profile. The dashboard and internal components access it over the private Compose network.

Wazuh dashboard

The **Wazuh dashboard** provides the analyst interface for alerts, agents, security modules, searches and visualisations.

A dashboard view is not the evidence itself. The analyst should be able to open event details and identify the supporting fields.

Wazuh agent

The **Wazuh agent** is installed on monitored endpoints to collect local telemetry and perform supported security functions.

VCC interns do not install agents on pod infrastructure. Pod telemetry is exported through the VCC control plane and delivered to the learner’s local collector using a pod-scoped credential.

Decoder and rule

- A **decoder** extracts fields or interprets structure.
- A **rule** evaluates decoded information and can create an alert.

For JSON records, Wazuh can use its JSON decoder and dynamic fields. Custom rules should use a documented local rule-ID range and be tested with `wazuh-logtest` before deployment.

---

4. Raw events, decoded events and alerts

Consider this synthetic VCC record:

```
{
  "schema_version": "1.0",
  "event_time": "2026-08-01T09:18:07Z",
  "ingest_time": "2026-08-01T09:18:10Z",
  "pod_id": "pod-03",
  "event_type": "authentication",
  "action": "login",
  "outcome": "success",
  "user": "svc-backup",
  "source_ip": "203.0.113.44",
  "destination_service": "learner-api",
  "correlation_id": "corr-7d9f0a",
  "synthetic": true
}
```

Raw event

The complete JSON line written by the collector.

Decoded event

Wazuh identifies fields such as `pod_id`, `action`, `outcome`, `user` and `source_ip`.

Alert

A custom rule might alert when a successful login from a source follows repeated failures for the same account. The alert includes rule metadata and selected event fields.

The analyst should retain the distinction:

- the raw record came from the VCC feed;
- the decoder exposed fields;
- the rule made a detection decision;
- the analyst adds context and reaches a case conclusion.

---

5. Time in security investigations

Event time

When the source says the activity occurred.

Ingest time

When the platform received or indexed the record.

Processing or alert time

When a rule evaluated the record and created an alert.

These times can differ because of buffering, network delay, batch delivery or processing load.

Clock skew

Clock skew is a difference between system clocks. A host running three minutes fast can make a later action appear earlier than a preceding event on another system.

Time-zone handling

Prefer UTC for correlation. Preserve the source time zone when available and document any conversion.

Example

```
Application event time: 09:14:21Z
Collector received:      09:15:05Z
Indexed:                 09:15:09Z
Alert created:           09:15:10Z
```

The 44-second delivery delay is not automatically suspicious. It becomes important when building a precise sequence.

---

6. Data-quality failures

Failure	What the analyst may see	Risk to conclusion	First checks
Auditing disabled	Expected event never exists	“No evidence” mistaken for “no activity”	Source policy and test event

Failure	What the analyst may see	Risk to conclusion	First checks
Agent or collector disconnected	Events stop suddenly	Blind period around incident	Last heartbeat, queue and service status
Parser failure	Raw data exists but fields are empty	Searches and rules miss records	Raw message, decoder logs and schema version
Schema drift	Old fields disappear or change type	Rules silently stop matching	Compare recent and older samples
Clock skew	Events appear out of order	False timeline	Source time, NTP status and ingest time
Duplicate ingestion	Counts double or thresholds fire	Inflated scope and false alerts	Event IDs, hashes and collector paths
Dropped events	Missing records during high volume	Incomplete scope	Queue, rate limits and volume metrics
Retention expiry	Older events unavailable	Root cause cannot be reconstructed	Index age and archive policy
Wrong field type	Exact/range searches behave oddly	False negatives or misleading results	Index mapping
Truncation	Command, URI or payload is incomplete	Important context missing	Source limits and raw record
Redaction error	Sensitive data remains or useful context removed	Privacy exposure or lost evidence	Logging policy and sanitisation tests

7. Schema drift

Schema drift occurs when field names, nesting, formats or data types change.

Version 1:

```
{"source_ip":"203.0.113.44","user":"student03"}
```

Version 2:

```
{"source":{"ip":"203.0.113.44"},"identity":{"name":"student03"}}
```

A rule expecting `source_ip` may stop working even though records still arrive.

Controls

- include a `schema_version` field;
- validate required fields in the exporter;
- maintain sample fixtures for each supported version;
- test decoders and rules in CI;
- monitor field-population rates;
- reject or quarantine unsupported versions rather than silently misparse them.

---

8. Validating a telemetry pipeline

When an expected event is missing, work from source to destination.

Source

- Is the activity configured to generate a log?
- Can a safe test event be produced?
- Is the local record present?

Collector

- Is the service running?
- Does it have permission to read the source?
- Is its cursor or checkpoint advancing?

Transport

- Is authentication valid?
- Are TLS and network connections successful?
- Are queues full or retries increasing?

Parsing

- Is the raw event received?
- Are required fields extracted?
- Did the schema change?

Indexing

- Is the target index writable and searchable?
- Are mappings correct?
- Is the selected time range based on the correct timestamp?

Detection

- Does the rule load successfully?
- Do the exact fields and values satisfy the condition?
- Is the threshold window correct?
- Was the event excluded or suppressed?

Dashboard

- Are filters hiding the record?
- Is the correct index pattern or data view selected?
- Is the browser displaying the intended time zone?

---

9. Worked example — alert disappeared after application update

Symptom

A rule that detects failed logins stops generating alerts after an application release.

Incorrect conclusion

> Failed login attempts have stopped.

Investigation

1. The application still writes JSON records.
2. The collector continues receiving current events.
3. Raw records now use `authentication.result` instead of `outcome`.
4. The Wazuh rule expects `outcome` equal to `failure`.
5. Indexed documents contain the new nested field, but the old field is empty.

Finding

The monitoring gap was caused by schema drift. Failed logins continued, but the existing rule no longer matched them.

Remediation

- update and test the decoder/rule;
- version the schema;
- add a CI fixture for both transition formats;

- monitor the population rate of required authentication fields;
- document the blind period.

---

10. Detection context and ATT&CK

MITRE ATT&CK helps describe adversary behaviour, but an ATT&CK technique label does not replace detection logic.

A useful detection design states:

1. **Threat hypothesis:** What behaviour are we concerned about?
2. **Required telemetry:** Which sources and fields can show it?
3. **Analytic:** What sequence, relationship or threshold should be evaluated?
4. **Expected benign causes:** Which authorised behaviours may look similar?
5. **Validation:** How will synthetic tests show that the detection works?
6. **Tuning record:** What changes were made and what coverage might be lost?

Current ATT&CK teaching should use Detection Strategies, Analytics and Data Components rather than treating a technique ID as a complete detection.

---

11. Common mistakes

Believing structured JSON is automatically correct

JSON can contain wrong timestamps, empty fields, unexpected types or attacker-controlled values.

Searching only the friendly message

Use structured fields and inspect the raw record. Friendly descriptions may omit important context.

Treating source IP as unquestionable

Proxies, NAT, forwarded headers and collection architecture affect which address is recorded.

Ignoring ingest delay

A delayed event can appear after an analyst has already closed a case.

Tuning by deleting noisy data

Noise can expose misconfiguration, stale credentials or operational problems. Understand the cause before excluding evidence.

Exposing internal services

The Wazuh indexer and server API should not be publicly exposed merely for convenience. Use the local dashboard and approved internal connections.

---

12. Guided exercise — pipeline failure classification

For each situation, identify the pipeline stage and likely investigative effect.

1. A Windows host never generated Event 4688 because process-creation auditing was disabled.
2. The VCC collector certificate expired and polling returned HTTP 401/403.
3. JSON records arrive, but `pod_id` is missing after a release.
4. The same file is read by two collectors.
5. A query searches the last hour using ingest time while the incident occurred two hours earlier and arrived late.
6. The index retained only seven days, but the suspected access occurred ten days ago.

Then write one validation step for each situation.

---

13. Review questions

1. What is the difference between log generation and collection?
2. Why should raw records remain available where policy permits?
3. Explain normalisation and one risk of over-normalising.
4. What is schema drift?
5. Why can event time and ingest time differ?
6. What does a decoder do in Wazuh?
7. What does the Wazuh indexer do?
8. Why should the indexer not be exposed publicly in the student profile?
9. Give three reasons why “no alert” does not prove “no attack.”
10. What six elements belong in a detection design?

References

- NIST SP 800-92 and SP 800-92 Rev. 1 Initial Public Draft.

- Wazuh official documentation: architecture, log collection, JSON decoder, custom rules, WQL and Docker deployment.
- OpenSearch official Query DSL and field-mapping documentation.
- MITRE ATT&CK v19.1 Detection Strategies, Analytics and Data Components.
- Microsoft Sysmon and Windows auditing documentation.
- AWS CloudTrail documentation.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: docs/secops-foundations/04-incident-response-and-playbook-development.md

Module 4 — Incident Response and Playbook Development

> **NeoLabs SOC Level 1 principle:** Incident response is not only what happens after an alert. Preparation, governance, logging, access control, communication and recovery readiness determine whether the organisation can respond effectively.

Module version: 0.2-draft
Review baseline: 1 August 2026
Expected study time: 5–7 hours

Learning objectives

By the end of this module, a learner should be able to:

- explain the relationship between cybersecurity risk management and incident response;
- describe the current NIST SP 800-61 Rev. 3 approach using the six CSF 2.0 Functions;
- compare current NIST framing with older preparation/detection/containment/eradication/recovery/lessons models without confusing them;
- distinguish an alert, cybersecurity event, declared incident and crisis;
- explain the roles of Level 1 analysts, incident responders, incident commanders, system owners and business stakeholders;
- create a practical playbook with triggers, evidence requirements, decision points, escalation and recovery checks;
- distinguish containment, eradication and recovery actions;
- explain why response actions require authority and evidence preservation;
- use an incident report and evidence log during a synthetic VCC scenario.

---

1. What incident response means

Cybersecurity incident response is the coordinated capability used to prepare for, detect, analyse, contain, address, recover from and learn from cybersecurity incidents.

It includes more than technical commands. Effective response depends on:

- policy and authority;
- current asset and identity information;

- useful logging;
- trained people;
- communication paths;
- tested backups;
- legal, privacy and contractual awareness;
- technical containment and recovery procedures;
- improvement after the incident.

Plain-language explanation

Incident response is how an organisation answers:

1. What happened?
2. Is it actually a cybersecurity incident?
3. What is affected?
4. What must be protected immediately?
5. Which evidence must be preserved?
6. Who is authorised to decide and act?
7. How do we remove or reduce the threat?
8. How do we restore safe operations?
9. What must change afterward?

---

2. Current NIST framing

NIST SP 800-61 Rev. 3, finalised in April 2025, aligns incident response with the six NIST Cybersecurity Framework 2.0 Functions:

```
GOVERN
IDENTIFY
PROTECT
DETECT
RESPOND
RECOVER
```

The six Functions are not simply six chronological boxes. Govern, Identify and Protect help prepare the organisation and reduce incident likelihood or impact. Detect, Respond and Recover contain the core operational incident-response activity, while lessons and changes feed back into all Functions.

2.1 Govern

Govern establishes direction, accountability and risk decisions.

Incident-response examples:

- policy and incident definitions;
- executive sponsorship;
- roles and authorities;
- legal, regulatory and contractual requirements;
- third-party responsibilities;
- escalation thresholds;
- risk tolerance;
- reporting and communication governance.

SOC Level 1 relevance

The Level 1 analyst follows approved definitions and escalation paths rather than inventing severity or response authority during an alert.

2.2 Identify

Identify develops understanding of assets, services, risks, dependencies and vulnerabilities.

Incident-response examples:

- asset inventory;
- data classification;
- identity and privilege inventory;
- dependency maps;
- vulnerability information;
- risk assessment;
- critical business-service identification.

SOC Level 1 relevance

An unusual login to an ordinary test account and an unusual login to a critical administrator account may require different priority because the identity and business context differ.

2.3 Protect

Protect applies safeguards to reduce the likelihood and impact of adverse events.

Incident-response examples:

- access control and MFA;
- secure configuration;
- patching;
- awareness training;

- data protection;
- resilient architecture;
- backup protection;
- logging and monitoring preparation.

SOC Level 1 relevance

Protection controls create the evidence and boundaries used during triage. Weak logging or shared credentials reduce the analyst’s ability to reach a defensible conclusion.

2.4 Detect

Detect identifies and analyses possible cybersecurity events.

Examples:

- event collection;
- SIEM rules and analytics;
- anomalous activity review;
- monitoring for control failure;
- alert validation;
- initial analysis and incident determination.

SOC Level 1 relevance

This is where much L1 triage work occurs: validate the alert, review evidence, search related activity, classify and escalate.

2.5 Respond

Respond contains actions taken after an incident is detected and declared.

Examples:

- incident management;
- analysis and scope expansion;
- internal and external communication;
- containment;
- mitigation;
- evidence handling;
- coordinated decision-making.

SOC Level 1 relevance

L1 analysts usually document and escalate. They may perform only the response actions explicitly authorised by a playbook.

2.6 Recover

Recover restores affected assets, services and operations and communicates recovery status.

Examples:

- restoration from trusted backups;
- rebuilding systems;
- credential reset;
- verification of safe service operation;
- monitoring after restoration;
- stakeholder communication;
- recovery improvement.

SOC Level 1 relevance

Analysts may monitor restored systems and confirm that alert patterns, telemetry and expected behaviour return to normal.

---

3. Older incident-handling phase models

Many textbooks and older procedures describe a sequence such as:

```
Preparation
  → Detection and Analysis
  → Containment
  → Eradication
  → Recovery
  → Lessons Learned
```

NIST SP 800-61 Rev. 2 used a four-phase life cycle that grouped containment, eradication and recovery together and included post-incident activity. That publication was superseded by Rev. 3 in April 2025.

The older terms remain operationally useful. Do not say they are “wrong,” but do not present them as the current NIST Rev. 3 structure.

Practical mapping

Traditional term	Current CSF-aligned location
Preparation	Govern, Identify and Protect, with preparation across all Functions
Detection and analysis	Detect and parts of Respond

Traditional term	Current CSF-aligned location
Containment and eradication	Respond
Recovery	Recover
Lessons learned	Feedback into Govern, Identify, Protect, Detect, Respond and Recover

4. Alert, event, incident and crisis

Security event

A security-relevant occurrence recorded by a system or reported by a person.

Alert

A detection-generated notification that an event or sequence deserves review.

Cybersecurity incident

An occurrence that meets the organisation’s declared incident criteria because it actually or imminently threatens systems, information, policy or operations and requires coordinated response.

Major incident or crisis

An incident with significant operational, financial, safety, legal, customer or reputational impact that requires executive coordination beyond the normal SOC process.

Important distinction

The SIEM can generate an alert. An authorised organisational process declares an incident. A Level 1 analyst may recommend declaration or escalate evidence, but the exact authority depends on policy.

5. Incident-response roles

5.1 SOC Level 1 analyst

- validates alert evidence;
- gathers initial context;
- identifies affected entities;

- records queries and a preliminary timeline;
- follows the relevant playbook;
- escalates on defined triggers;
- avoids unauthorised containment.

5.2 SOC Level 2 or incident responder

- expands scope;
- correlates additional sources;
- validates compromise and impact;
- coordinates authorised containment;
- preserves and requests deeper evidence;
- develops eradication and recovery recommendations.

5.3 Incident commander

The **incident commander** coordinates the response, maintains priorities, assigns owners, manages decisions and ensures communication. The commander does not need to perform every technical investigation personally.

5.4 System and service owners

They explain expected operation, approve or perform service-impacting actions and assess business consequences.

5.5 IT, cloud and application teams

They may isolate hosts, revoke credentials, change firewall or IAM policies, deploy fixes, restore services and validate normal operation.

5.6 Legal, privacy, communications and management

These stakeholders assess obligations, sensitive-data exposure, notification, public communication and business risk.

VCC training boundary

Mentors and operators retain containment authority over VCC infrastructure. Interns investigate the approved student-facing evidence and make recommendations.

---

6. Incident classification and declaration

An organisation should define incident categories and thresholds before an event occurs.

Possible factors:

- affected asset criticality;
- privilege of affected identities;
- confidentiality, integrity or availability impact;
- number of affected users or systems;
- persistence or lateral movement;
- data access or exfiltration evidence;
- legal or contractual significance;
- operational disruption;
- confidence in the evidence;
- whether the condition remains active.

Severity and confidence remain separate

A suspected compromise of a privileged cloud account may be potentially critical even when initial confidence is medium. Urgent escalation can be justified by risk while investigation continues.

---

7. Containment, eradication and recovery

7.1 Containment

Containment limits the spread, activity or impact of the incident.

Examples:

- revoke a compromised session;
- disable or restrict an account;
- isolate an endpoint;
- block a known malicious destination;
- remove an exposed service from public access;
- temporarily disable a vulnerable function;
- preserve a system before rebuilding.

Containment caution

Containment can disrupt business, alert an adversary or destroy volatile evidence. It must be proportionate and authorised.

7.2 Eradication

Eradication removes the cause or remaining threat.

Examples:

- remove malicious persistence;
- patch the exploited vulnerability;
- delete unauthorised accounts after evidence preservation;
- rotate exposed secrets;
- remove a malicious application or configuration;
- close the exploited access path.

Eradication is not only deleting a suspicious file. The root cause and all affected scope must be addressed.

7.3 Recovery

Recovery restores trustworthy operation.

Examples:

- rebuild from a trusted image;
- restore clean data from backup;
- verify patched configuration;
- re-enable services gradually;
- monitor closely for recurrence;
- confirm logging and detection are working;
- communicate service status.

Recovery validation

A service being reachable does not prove recovery is complete. Validate identity, integrity, security controls, telemetry and expected business functions.

---

8. Evidence preservation during response

Response and evidence collection can conflict. For example, restarting a system may restore service but remove volatile evidence.

Level 1 analysts should:

- record important event IDs and timestamps;
- preserve approved exports before filters or retention change;
- document who performed each action and when;
- distinguish source evidence from screenshots;

- avoid modifying the affected system without authority;
- record visibility gaps created by containment;
- protect credentials and personal information.

The NeoLabs evidence log is a training record, not a substitute for formal forensic chain-of-custody procedures where those are required.

---

9. What a playbook is

A **playbook** is a documented, repeatable response guide for a particular incident type or trigger.

A playbook supports consistent action under pressure. It does not remove analyst judgment. It should define decision points, authority and stop conditions rather than list commands without context.

Playbook versus runbook

Terminology differs, but a useful distinction is:

- **Playbook:** broader incident strategy, decisions, roles and coordinated actions.
- **Runbook:** detailed procedure for a specific repeatable technical task.

Example:

- Account-takeover playbook: triage, declaration, communication, containment and recovery decisions.
- Session-revocation runbook: exact approved steps to revoke sessions in one identity platform.

---

10. Required playbook sections

10.1 Purpose and scope

State:

- incident type;
- systems and environments covered;
- authorised users;
- exclusions;
- linked policies.

10.2 Trigger

Define what starts the playbook:

- SIEM alert;
- user report;
- threat-intelligence notification;
- monitoring outage;
- cloud-provider alert;
- confirmed vulnerability exposure.

A trigger starts investigation. It does not necessarily confirm an incident.

10.3 Required evidence

List the minimum sources and fields needed.

Example for account takeover:

- failed and successful authentication;
- MFA result;
- session creation and revocation;
- source and device context;
- password or email changes;
- sensitive actions after login;
- account owner confirmation;
- telemetry-health status.

10.4 Initial L1 actions

Keep them bounded and reproducible:

1. validate the underlying event;
2. establish absolute UTC range;
3. identify account, source, asset and session;
4. search preceding and following activity;
5. check known maintenance and account role;
6. document observations and queries;
7. classify and escalate on defined conditions.

10.5 Escalation criteria

Examples:

- privileged account affected;
- successful access after suspicious failures;

- sensitive account or data change;
- multiple accounts targeted;
- active session remains valid;
- missing telemetry after the success;
- possible cross-pod data exposure;
- response action needed;
- uncertainty cannot be resolved within L1 authority.

10.6 Containment options

Each option should state:

- authorising role;
- operational impact;
- evidence consideration;
- verification step;
- rollback or recovery dependency.

10.7 Eradication and recovery

Define how root cause is addressed and how trustworthy operation is confirmed.

10.8 Communication

State:

- who receives initial escalation;
- who owns stakeholder updates;
- approved communication channels;
- required update frequency;
- what information must not be placed in public channels.

10.9 Closure and improvement

Require:

- final classification;
- timeline;
- affected scope;
- actions and owners;
- evidence references;
- unresolved risks;
- detection and logging improvements;
- playbook revision if needed.

11. Worked playbook — suspected account takeover

Purpose

Investigate authentication failures followed by a successful login and sensitive account activity in an authorised synthetic VCC scenario.

Trigger

A Wazuh rule reports success after repeated failures for the same account.

L1 evidence requirements

- raw failure and success records;
- user and source address;
- authentication method;
- session ID;
- post-login actions;
- other accounts targeted by the source;
- telemetry-health events;
- approved maintenance or account-owner context.

L1 workflow

1. Set an absolute UTC range beginning 15 minutes before the first failure.
2. Validate distinct event IDs and exclude duplicate ingestion.
3. Count failures for the account and source.
4. Confirm whether the success came from the same source.
5. Pivot to the created session.
6. Identify account, authorisation and application events.
7. Search for other targeted users.
8. Identify telemetry gaps.
9. write observation, interpretation and conclusion.
10. Escalate if success, sensitive action, privileged identity, multi-account targeting or visibility gap is present.

Potential containment recommendations

An authorised responder may:

- revoke the suspicious session;
- reset or rotate credentials;
- require fresh MFA enrolment when appropriate;
- temporarily restrict the account;
- block the source when justified and operationally safe;

- preserve relevant identity and application logs.

The intern documents recommendations and observed scenario-controller actions but does not directly administer VCC identity systems.

Eradication questions

- How were credentials obtained or guessed?
- Are other credentials or sessions affected?
- Was a weak authentication or recovery flow involved?
- Was the account used to create persistence?
- Which control or vulnerability enabled access?

Recovery checks

- suspicious sessions revoked;
- credentials rotated;
- expected owner access restored;
- sensitive account values verified;
- monitoring and logging healthy;
- no repeat activity during the defined observation period;
- detection and rate-limit controls reviewed.

---

12. Playbook anti-patterns

A list of destructive commands

A playbook should not assume every alert deserves isolation, deletion or blocking.

No authority information

Analysts need to know who can approve each action.

No evidence requirements

Without evidence criteria, the team may act on an alert title alone.

One path with no decision points

Real incidents differ. Include conditions for close, continue, escalate and declare.

No recovery validation

“Service restored” is incomplete without trust and monitoring checks.

Secrets inside the playbook

Use secret references, never actual passwords, tokens or private endpoints.

No owner or review date

Outdated playbooks can be worse than no playbook when tools and systems change.

---

13. Incident communication

Good incident communication is:

- factual;
- time-stamped;
- clear about uncertainty;
- appropriate for the audience;
- limited to approved recipients;
- consistent with the case record.

Technical update example

> At 09:18:07Z, synthetic authentication telemetry recorded a successful login for `svc-backup` from the source that produced five earlier failures. The resulting session later accessed a profile and attempted cross-pod evidence access, which the application denied. A process-telemetry gap began before the success, so endpoint activity cannot currently be confirmed or excluded. Classification: suspicious synthetic incident; confidence medium-high. Session revocation is recorded. Further owner and telemetry review is requested.

Poor update

> Hacker entered the system and tried to steal everything.

The poor update overstates identity, intent and impact.

---

14. Post-incident improvement

Improvement should consider:

- logging fields and source coverage;
- detection logic and false-positive patterns;
- playbook clarity;
- escalation delay;
- authority and communication gaps;
- backup and recovery performance;
- identity and access controls;
- asset and dependency records;
- training needs;
- third-party coordination.

A lessons-learned review should not become a blame session. Focus on system and process improvement while preserving accountability.

---

15. Guided exercise

Using Practice Lab 01:

1. decide whether the evidence meets the training definition of an incident;
2. map observed actions to Detect, Respond and Recover;
3. identify which Govern, Identify and Protect activities should have existed before the alert;
4. draft an account-takeover playbook using the template below;
5. identify three actions outside L1 authority;
6. write one technical update and one management-friendly summary;
7. list five lessons or control improvements.

Playbook draft template

```
Title:
Owner:
Version/review date:
Purpose and scope:
Trigger:
Required evidence:
Initial L1 actions:
Decision points:
Escalation criteria:
Incident declaration authority:
Containment options and authorisers:
Eradication requirements:
Recovery checks:
Communication plan:
Evidence and reporting requirements:
Closure criteria:
Post-incident review:
References:
```

---

16. Review questions

1. How does NIST SP 800-61 Rev. 3 organise incident-response recommendations?
2. Why is the older six-step model still useful but not the current NIST structure?
3. Who normally declares an incident?
4. What is the difference between containment and eradication?
5. Why can containment damage evidence?
6. What makes a playbook different from a simple command list?
7. Name five required playbook sections.
8. Why should recovery include logging and monitoring validation?
9. What information belongs in an incident update?
10. How do lessons feed back into all six CSF Functions?

Authoritative references

- NIST SP 800-61 Rev. 3, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*.
- NIST Cybersecurity Framework 2.0.
- NIST SP 800-61 Rev. 2, withdrawn and superseded, for historical incident-handling phase terminology.
- CISA, *Federal Government Cybersecurity Incident and Vulnerability Response Playbooks*, used as public playbook structure context rather than as VCC policy.
- NeoLabs evidence, incident-report and query-journal templates.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: docs/secops-foundations/05-windows-and-sysmon-investigation.md

Module 5 — Windows and Sysmon Investigation

Learning objectives

By the end of this module, a SOC Level 1 analyst should be able to:

- distinguish Windows security, system, PowerShell and Sysmon telemetry;
- build a short authentication and process timeline;
- recognise common high-value event relationships;
- separate suspicious behaviour from confirmed malicious activity;
- document evidence without exposing credentials or private infrastructure.

1. Windows evidence sources

A Windows investigation rarely depends on one event. The analyst correlates records that answer different questions.

Source	Typical questions
Security log	Who signed in, from where, with which account and logon type?
System log	Did a service, driver or operating-system component fail or change?
PowerShell logs	What commands or script blocks were executed?
Microsoft Defender logs	Was malware, a potentially unwanted application or suspicious behaviour detected?
Sysmon	Which process, network, file, registry or image-loading activity occurred?
Application logs	Did the affected business application report authentication or execution errors?

No single event source is complete. Missing telemetry must be recorded as an investigation limitation rather than silently treated as evidence that nothing happened.

2. Authentication timeline

Begin with the account, device and time window supplied in the alert. Expand the window enough to see activity immediately before and after the trigger.

Important Windows authentication concepts include:

- successful and failed logons;
- interactive, network, service, batch and remote-interactive logon types;

- source workstation or network address;
- privileged-logon indicators;
- account lockout and password-change activity;
- logoff or session termination.

A useful timeline might show:

```
09:12:03  repeated failed network logons for trainee-a
09:13:20  successful remote-interactive logon for trainee-a
09:13:42  privileged process created in the new session
09:14:10  outbound connection to an unusual destination
09:16:02  session terminated
```

The timeline does not prove compromise by itself. It establishes sequence, scope and the next questions to test.

3. Process investigation

For each suspicious process, capture:

- process image and full path;
- parent process and parent path;
- command line;
- user and session identifier;
- hash when available;
- signature or publisher information when available;
- start time;
- network, file or registry activity linked to the process.

A process name is weak evidence. Attackers can rename files, while legitimate tools can appear suspicious when used by administrators. Parent-child relationships and command-line context are usually more useful.

Examples of questions:

- Was the process launched by the expected parent?
- Did an Office application, browser or script host create a command shell unexpectedly?
- Was the executable started from a user-writable or temporary path?
- Did the command line contain encoded content, credential access attempts or unusual download behaviour?
- Did the process create persistence or connect externally?

4. Sysmon relationships

Sysmon records detailed activity, but the analyst still needs correlation. High-value relationships include:

```
process creation
  -> network connection
  -> file creation
  -> registry change
  -> child process
```

Use stable identifiers, such as process GUIDs, when they are available. Process IDs can be reused after a process ends and should not be treated as globally unique.

Process creation

Capture the image, command line, parent, user, hashes and process GUID. Compare the path and parent relationship with the host's normal pattern.

Network connection

Link the connection back to the process. Record destination IP or hostname, port, protocol, connection direction and whether the destination is expected for that application.

File creation and modification

Record the path, creating process and timestamp. Files in temporary directories, startup folders or unusual user-profile locations deserve context, not automatic conviction.

Registry activity

Focus on persistence locations, security-setting changes and application-specific configuration. A registry modification is meaningful only when the key, value, actor and timing are understood.

5. PowerShell review

PowerShell is a legitimate administrative tool and a common attack surface. Review:

- script-block content where available;
- module and engine events;
- parent process;
- user and session;
- encoded or obfuscated content;
- download, execution-policy or security-control changes;
- follow-on process and network activity.

Do not paste sensitive command output into public repositories. Redact tokens, passwords, private URLs and identifying student information.

6. Triage decision

Use an evidence-based disposition:

Benign or expected

The activity matches an approved administrative or learning task, the account and device are expected, and no contradictory evidence is present.

Suspicious — investigate further

The activity is unusual or incomplete, but available evidence does not yet establish malicious intent or impact.

Likely malicious — escalate

Multiple independent signals support unauthorised activity, such as an unexpected remote logon followed by suspicious process execution and external communication.

False positive or detection-quality issue

The event is real, but the rule or enrichment produced misleading severity or context. Preserve the evidence and recommend a safe tuning change.

7. Evidence checklist

For every Windows investigation, record:

1. alert identifier and trigger time;
2. affected host and account;
3. investigation time range and timezone;
4. relevant event sources;
5. authentication sequence;
6. process tree or key parent-child relationship;
7. network, file and registry evidence;
8. missing evidence and limitations;
9. disposition and confidence;
10. recommended containment or escalation.

8. Practice exercise

Using a synthetic dataset, identify a failed-login sequence followed by a successful remote-interactive logon. Build a five-event timeline, identify the first process created in the session and decide whether the evidence supports benign activity, suspicious activity or escalation.

Submit the result using the evidence-log, query-journal and incident-report templates. Do not include credentials, private pod addresses or mentor-only ground truth.

Source: docs/secops-foundations/06-linux-web-and-cloud-log-investigation.md

Module 6 — Linux, Web and Cloud Log Investigation

Learning objectives

By the end of this module, a SOC Level 1 analyst should be able to:

- identify useful Linux, web-server, application and cloud-audit sources;
- correlate authentication, process, network and application events;
- recognise evidence-quality problems caused by time, parsing or missing fields;
- build a cross-source timeline without assuming that every unusual event is malicious;
- escalate findings with clear scope and limitations.

1. Linux evidence sources

Common Linux sources include:

Source	Typical evidence
`journald` or system logs	service starts, failures, kernel and authentication messages
Authentication logs	SSH, sudo, account and session activity
Audit logs	system calls, file access, process execution and policy events
Shell history	limited user-command context when available and trustworthy
Package-manager logs	software installation, upgrade and removal
Cron and systemd timers	scheduled execution and persistence
Web-server logs	requests, response codes, user agents and source addresses
Application logs	authentication, errors, business events and API activity
Database logs	connection, authentication and query-related events
Cloud audit logs	API calls, identity, source address and resource changes

Shell history is not a complete or tamper-resistant record. Treat it as supporting context, not as the only evidence of execution.

2. Linux authentication triage

For SSH or privilege-related alerts, capture:

- account name;
- source address;
- authentication method;
- success or failure;
- session start and end;
- `sudo` or privilege-transition activity;
- processes created in the session;
- changes to accounts, keys or authentication configuration.

A repeated-failure sequence followed by a success is important only when combined with context. Questions include:

- Is the source expected for the learner or administrator?
- Was the account active at that time?
- Did the successful session perform unusual activity?
- Were authorised maintenance or lab exercises scheduled?
- Did the source attempt multiple accounts or hosts?

3. Process and persistence review

Review execution from temporary, user-writable and hidden locations carefully. Record the process, parent, user, command line and linked network activity.

Common persistence locations to examine in an authorised investigation include:

- user and system cron entries;
- systemd services and timers;
- shell profile files;
- SSH `authorized_keys`;
- application startup hooks;
- container restart policies;
- cloud-init or deployment scripts.

Presence in one of these locations is not automatically malicious. Package installers and administrators use them legitimately. The analyst must determine who created the entry, when, why and what it executes.

4. Web-server investigation

Web access logs often provide:

```
source address
request time
HTTP method
request path
status code
response size
referrer
user agent
request duration
```

Application and reverse-proxy logs may add authenticated user, request ID, route name, upstream status and error details.

High-value patterns

Investigate patterns such as:

- many failed logins followed by a success;
- repeated requests to non-existent administrative paths;
- unusual methods or content types;
- path traversal strings or unexpected encoded paths;
- a request producing an application exception;
- upload activity followed by execution-like behaviour;
- a single request ID appearing across proxy, application and database logs.

A suspicious request does not prove successful exploitation. Confirm the response, application behaviour, downstream logs and resulting system changes.

5. Application and database correlation

Application logs provide business context that infrastructure logs may lack. Use correlation identifiers where available.

Example timeline:

```
10:21:03  reverse proxy accepts POST /login from source A
10:21:03  application records failed authentication for user trainee-b
10:21:04  database records expected account lookup
10:22:18  reverse proxy accepts another POST /login from source A
10:22:18  application records successful authentication
10:22:24  application records export request for an unusual resource
```

Confirm that clocks and timezones align before ordering events. A two-minute clock difference can create a misleading sequence.

6. Cloud audit investigation

Cloud audit records commonly include:

- identity or role;
- API action;
- resource;
- source address and user agent;
- region;
- success or error result;
- request parameters;
- request or event identifier.

For an unexpected cloud action, determine:

1. which identity performed it;
2. how the identity authenticated;
3. whether the source and user agent are expected;
4. which resources were affected;
5. whether related actions occurred before or after it;
6. whether the action matches an approved lab scenario.

Never copy live cloud keys, session tokens or unredacted account identifiers into the public toolkit.

7. Data-quality checks

Before making a conclusion, check:

- timestamp format and timezone;
- host and source identity;
- duplicate events;
- parser or decoder errors;
- missing fields;
- delayed ingestion;
- inconsistent field names across sources;
- truncation of commands, URLs or messages;
- whether logs are synthetic, sanitised or live.

A data-quality defect can be the root cause of a misleading alert. Record it separately from the security disposition.

8. Correlation method

Use a repeatable method:

1. define the alert entity and time window;

2. collect the original event;
3. pivot by account, host, source address, process, request ID or resource;
4. normalise time and field names;
5. place events in chronological order;
6. test benign and malicious explanations;
7. identify gaps;
8. assign disposition and confidence;
9. document escalation or tuning recommendations.

9. Practice exercise

Investigate a synthetic web-login alert that includes Linux authentication events, reverse-proxy requests and application records. Determine whether the successful login is connected to the earlier failures, identify any follow-on activity and produce a short evidence-based escalation note.

The submission must state which logs were available, which were missing and how those limitations affected confidence.

Source: docs/secops-foundations/07-wazuh-alert-investigation-and-tuning.md

Module 7 — Wazuh Alert Investigation and Safe Tuning

Learning objectives

By the end of this module, a SOC Level 1 analyst should be able to:

- move from a Wazuh alert to the underlying evidence;
- identify decoder, rule, agent and event fields that affect interpretation;
- use filters and pivots to build an investigation timeline;
- distinguish alert disposition from rule-quality feedback;
- propose safe tuning without hiding meaningful security activity.

1. Start with the alert record

Capture the original alert before changing filters or running broader searches. Record:

- alert identifier;
- rule ID, level and description;
- agent or source identity;
- event timestamp and ingestion timestamp;
- decoder or integration name;
- full original event when available;
- relevant structured fields;
- scenario or assignment context.

The rule description is a hypothesis, not the final incident conclusion.

2. Understand the Wazuh processing path

A simplified path is:

```
source event
  -> collection
  -> decoding and field extraction
  -> rule evaluation
  -> alert creation
  -> indexing
  -> dashboard search and visualisation
```

An investigation can fail at any stage. A missing alert may mean:

- the source did not generate the event;
- the collector did not receive it;

- the event was malformed;
- the decoder did not extract expected fields;
- the rule conditions did not match;
- the alert was indexed under an unexpected time or field;
- the dashboard filter excluded it.

Do not jump directly to changing a rule before checking the earlier stages.

3. Alert-to-evidence pivots

Useful pivots include:

- agent ID or host name;
- account;
- source and destination address;
- process image, process ID or process GUID;
- rule ID;
- event ID;
- request or correlation ID;
- file path or hash;
- scenario ID;
- pod ID supplied by the server-authorised telemetry stream.

Begin with a narrow time window and expand only when needed. Preserve the timezone in the query journal.

4. Rule fields and interpretation

When reviewing an alert, separate:

Source facts

Values that came from the original event, such as account, process, source address, path or result.

Decoder output

Fields extracted or normalised by Wazuh. A decoder error can mislabel, omit or split data.

Rule metadata

Rule ID, level, groups, description, frequency and relationship to parent or child rules.

Enrichment

Information added from inventories, threat intelligence or lookup data. Enrichment can be missing, stale or incorrect and must not replace source evidence.

5. Investigation workflow

1. Save the original alert.
2. Confirm the affected entity and timestamp.
3. Inspect the raw event and decoded fields.
4. Search for the same entity immediately before and after the alert.
5. Pivot to related authentication, process, network, file or application activity.
6. Compare the behaviour with approved lab activity.
7. Record gaps and data-quality concerns.
8. Assign a disposition and confidence.
9. Escalate, close or recommend tuning.

6. Disposition and rule quality are different

An alert can be a true positive event but still have poor severity. It can also be a false positive caused by a decoder or rule issue.

Use two separate conclusions:

Security disposition

- expected activity;
- suspicious activity requiring more evidence;
- likely malicious activity requiring escalation;
- confirmed authorised simulation.

Detection-quality assessment

- rule behaved correctly;
- severity too high or too low;
- missing context or enrichment;
- duplicate or noisy alert;
- decoder issue;
- field-mapping issue;
- rule logic requires review.

This separation prevents analysts from weakening a rule simply because one event was benign.

7. Safe tuning principles

A tuning proposal should be narrow, testable and reversible.

Good proposals may:

- add a condition based on a stable, well-understood field;
- reduce duplicate alerts while preserving the first and most important signal;
- correct a decoder or field mapping;
- add context to the alert description;
- change severity based on verified impact or privilege;
- create an allow-list limited to an approved account, host, process path and time-bound use case.

Avoid broad exclusions such as:

```
ignore all PowerShell
ignore this source network
ignore all administrator logons
ignore the entire rule group
```

Broad suppression can hide unrelated malicious activity.

8. Tuning proposal template

Document:

- rule ID and current behaviour;
- evidence showing the problem;
- proposed change;
- expected effect;
- possible blind spots;
- test dataset;
- rollback method;
- reviewer and approval status.

Students propose tuning. They do not change shared VCC control-plane rules, mentor dashboards or production detections.

9. Validation cases

Every proposed change should be tested against:

1. the benign event that created noise;
2. a similar malicious or suspicious event that must still alert;
3. unrelated events that should remain unchanged;
4. malformed or missing-field events;

5. duplicate events;
6. the expected rule level and groups.

Use synthetic or sanitised fixtures. Do not copy live incidents into this public repository.

10. Escalation package

A strong Wazuh escalation contains:

- alert and rule details;
- raw event evidence;
- timeline of related activity;
- affected entities;
- analyst queries;
- security disposition and confidence;
- detection-quality observation;
- recommended containment or next action;
- limitations.

11. Practice exercise

Investigate a synthetic Wazuh authentication alert that fires repeatedly for the same sequence. Determine the security disposition, identify whether duplication is caused by repeated source events or rule behaviour, and write a tuning proposal that reduces noise without suppressing the successful-login event.

Source: docs/secops-foundations/08-case-management-reporting-and-capstone.md

Module 8 — Case Management, Reporting and SOC Capstone

Learning objectives

By the end of this module, a SOC Level 1 analyst should be able to:

- maintain an investigation record that another analyst can reproduce;
- distinguish facts, assumptions, analysis and recommendations;
- communicate severity, confidence and business impact clearly;
- hand off a case without losing evidence or context;
- complete a defensive capstone using the NeoLabs templates.

1. The case record

A case is more than an alert screenshot. It is the organised record of what was reported, what was examined, what was found, what remains unknown and what should happen next.

A minimum case record includes:

- case or issue identifier;
- title and current status;
- owner and reviewers;
- alert source;
- affected accounts, hosts, applications or resources;
- detection, triage and escalation timestamps;
- evidence register;
- query journal;
- timeline;
- disposition and confidence;
- recommended actions;
- limitations and unanswered questions.

2. Facts, analysis and assumptions

Keep these categories separate.

Fact

A directly observed and preserved item, such as:

```
The authentication event records a successful remote-interactive logon for trainee-a at 09:13:20 UTC.
```

Analysis

An interpretation supported by facts:

```
The success occurred 77 seconds after repeated failures from the same synthetic source, increasing the
likelihood that the events are related.
```

Assumption

A statement not yet proven:

```
The source may represent the same operator throughout the sequence.
```

Recommendation

A proposed action:

```
Escalate for review of the account's approved activity and preserve the related process telemetry.
```

Mixing these categories makes reports difficult to trust.

3. Severity and confidence

Severity describes the potential or observed effect. Confidence describes how strongly the evidence supports the conclusion.

Example:

```
Severity: High
Confidence: Medium
Reason: The account obtained a privileged session and launched an unusual process, but endpoint network
telemetry is incomplete.
```

Do not raise confidence merely because an alert has a high rule level. Do not lower severity solely because the dataset is synthetic; assess the scenario as instructed while clearly marking the evidence as synthetic.

4. Timeline construction

A useful timeline:

- uses one timezone;
- orders events chronologically;
- identifies the source of each entry;
- distinguishes event time from ingestion time when relevant;
- avoids duplicate entries;
- includes the analyst's key pivots;
- marks gaps or uncertain ordering.

Time (UTC)	Source	Entity	Event	Significance
09:12:03	Windows Security	trainee-a	Failed logon	Start of repeated failures
09:13:20	Windows Security	trainee-a	Successful remote logon	First success in sequence
09:13:42	Sysmon	host-01	Process creation	Follow-on execution

5. Evidence handling

The evidence log should record:

- evidence ID;
- source and collection method;
- timestamp;
- file, event or screenshot reference;
- checksum when a file is submitted;
- analyst notes;
- redactions;
- storage location.

Do not alter original evidence to make a report look cleaner. Create a redacted copy and retain the original only in the approved private location.

The public toolkit and student submissions must not contain:

- passwords or tokens;
- private keys or certificates;
- private pod URLs;
- AWS account details;
- unredacted personal data;
- mentor ground truth;
- production evidence.

6. Query journal

A query journal makes the investigation reproducible. For each query, record:

- tool and data source;
- exact query or command;
- time range and timezone;
- purpose;
- result count;
- useful findings;
- limitations;
- next pivot.

A query that returns no results is still relevant when the source, time range and field assumptions are documented.

7. Handoff and escalation

A handoff should allow the next analyst to continue without repeating all work.

Include:

1. why the case matters;
2. current disposition and confidence;
3. affected entities;
4. key timeline events;
5. actions already taken;
6. evidence location;
7. unresolved questions;
8. recommended next steps;
9. deadlines or containment urgency.

Use Slack for approved collaboration and GitHub for official evidence, reports, feedback and submissions. Use WhatsApp only for urgent programme announcements or schedule changes, not as the authoritative case record.

8. Closure criteria

A case may be closed when:

- the alert has an evidence-supported disposition;
- required escalation or containment has been completed or accepted by the responsible operator;
- evidence and queries are documented;
- limitations are recorded;
- detection-quality feedback is submitted where needed;
- the final report is reviewed;

- credentials and sensitive data have been removed from the submission.

A lack of evidence is not automatically evidence of benign activity. Close as inconclusive or escalate when required information is unavailable.

9. Capstone scenario

The capstone combines authentication, endpoint, web and application telemetry from an authorised synthetic VCC scenario.

The learner must:

1. confirm the assigned pod scope shown by the toolkit;
2. capture the original Wazuh alert;
3. build a query journal;
4. correlate at least three telemetry sources;
5. construct a timeline;
6. identify affected entities;
7. state at least two competing explanations;
8. test those explanations against evidence;
9. assign disposition, severity and confidence;
10. recommend containment, escalation or tuning;
11. complete the incident report and evidence register;
12. submit through the approved GitHub assignment workflow.

10. Capstone assessment rubric

Area	Weight	Evidence of success
Scope and safety	10%	Uses only assigned synthetic evidence and protects credentials
Evidence collection	20%	Preserves relevant events and records sources accurately
Query method	15%	Queries are reproducible and logically sequenced
Correlation and timeline	20%	Links events across sources without unsupported claims
Disposition and confidence	15%	Conclusion is supported and limitations are explicit
Communication	10%	Report is clear, concise and suitable for handoff
Detection feedback	10%	Tuning or quality recommendation is safe and testable

11. Final analyst checklist

Before submission, confirm:

- every statement is labelled as fact, analysis, assumption or recommendation where needed;
- timestamps use a stated timezone;
- screenshots are readable and redacted;
- commands and queries can be reproduced;
- the assigned pod was not selected through a client-controlled parameter;
- no credential material is committed;
- limitations are honest;
- the report answers what happened, what was affected, how confident the analyst is and what should happen next.

Source: docs/wazuh-handbook/01-wazuh-architecture-and-neolabs-deployment.md

Wazuh SOC Level 1 Handbook — Module 1

Architecture, Data Flow and the NeoLabs Student Deployment

NeoLabs tested baseline: Wazuh 4.14.7
Module version: 0.2-draft
Research and review date: 1 August 2026
Audience: Beginner-to-intermediate SOC Level 1 interns

> Wazuh is not one program running in one window. It is a set of components that collect, analyse, store and display security data. Understanding which component performed each action is essential for troubleshooting and investigation.

Learning objectives

By the end of this module, a learner should be able to:

- explain the roles of the Wazuh agent, server/manager, indexer and dashboard;
- describe how a source event becomes a decoded event, alert and searchable document;
- distinguish event collection, decoding, rule evaluation, indexing and visualisation;
- explain the difference between Wazuh alerts and archived events;
- identify the ports commonly used by the standard Wazuh components and explain the NeoLabs exposure restrictions;
- describe the local containerised student deployment;
- explain how VCC pod telemetry reaches the learner without installing an agent in the pod;
- identify which settings the learner controls and which pod-scope settings remain operator-controlled;
- perform a basic health and data-flow check without exposing secrets.

1. What Wazuh is

Wazuh is an open-source security platform that provides capabilities such as:

- log collection and analysis;
- security-event detection;
- file integrity monitoring;
- security configuration assessment;
- vulnerability-detection context;
- malware and rootkit-related monitoring;
- cloud and container monitoring;
- inventory and compliance-oriented views;
- agent management and dashboard investigation.

In practical SOC work, Wazuh acts as a security telemetry and detection platform. It can collect events from agents, files, Windows channels, syslog and supported integrations; decode and evaluate those events; forward alerts for indexing; and present them to analysts in the dashboard.

Plain-language analogy

Think of a Wazuh deployment as a security newsroom:

- **Agent or collector:** gathers reports from the field.
- **Manager:** reads the reports, extracts important facts and applies editorial rules about what deserves attention.
- **Indexer:** organises the reports so they can be found quickly.
- **Dashboard:** gives analysts an interface for searching, reviewing and visualising the organised information.

The analogy is useful, but remember that a security event can be delayed, duplicated, incorrectly parsed or absent. The analyst must validate the pipeline.

---

2. Core Wazuh components

2.1 Wazuh agent

A **Wazuh agent** is software installed on a monitored endpoint. Depending on configuration, it can collect or produce information such as:

- operating-system and application logs;
- Windows Event channels;
- file-integrity changes;
- system inventory;
- security configuration assessment results;

- selected command or audit output;
- malware or rootkit-related observations;
- agent health and status information.

The agent normally communicates with the Wazuh server over an authenticated channel.

Important analyst limitation

An agent can report only what its operating system, applications and Wazuh configuration make available. An active agent does not guarantee that every required event category is enabled or correctly parsed.

VCC boundary

SOC interns do **not** install, enrol or administer Wazuh agents inside VCC pods. The pods remain operator-managed. The approved VCC log exporter creates a separate synthetic telemetry feed that is delivered to the learner's local collector.

2.2 Wazuh server or manager

The **Wazuh server** includes the manager processes responsible for receiving, decoding, analysing and coordinating Wazuh data.

Important functions include:

- receiving agent or approved collector data;
- pre-decoding common message information;
- applying decoders to extract fields;
- applying rules and correlation conditions;
- writing alert and archive records;
- managing agent registration and grouping where used;
- exposing the Wazuh server API;
- coordinating supported integrations and active-response functions.

The container in the NeoLabs stack is named:

```
wazuh.manager
```

Manager is not the index

The manager analyses events, but analysts normally search indexed alert documents through the dashboard. When troubleshooting, distinguish "the manager generated the alert" from "the indexer stored and returned the alert."

2.3 Filebeat in the Wazuh server container

The official single-node Wazuh container topology includes Filebeat configuration in the manager container. Filebeat forwards Wazuh alert data securely to the Wazuh indexer.

A problem between manager and indexer can produce this situation:

```
Manager alert file contains the alert
        but
Dashboard search does not show it
```

That difference is a useful troubleshooting clue.

2.4 Wazuh indexer

The **Wazuh indexer** is the search and storage component based on OpenSearch technology. It stores documents in indices and makes them searchable.

The indexer handles:

- index creation and storage;
- field mappings;
- distributed search functions;
- security and access-control configuration;
- queries and aggregations;
- data retention through index-management policies where configured.

The NeoLabs Compose service is:

```
wazuh.indexer
```

Field mapping matters

An indexed value can be mapped as a date, number, IP address, keyword or analysed text. Mapping affects equality, range, sorting and aggregation behaviour. A field being visible in JSON does not guarantee that every query type will work correctly.

2.5 Wazuh dashboard

The **Wazuh dashboard** is the browser interface for:

- security-event and alert investigation;
- agent and server management views;
- security modules and compliance-oriented dashboards;
- Wazuh Query Language filters in supported areas;
- OpenSearch-backed Discover and visualisation functions;

- saved searches and dashboards;
- component configuration available to the logged-in role.

The NeoLabs service is:

```
wazuh.dashboard
```

The standard student profile publishes only the dashboard to the host and binds it to loopback:

```
127.0.0.1:8443
```

This means another device cannot normally reach the dashboard over the network unless the learner or operator deliberately changes the profile. Such a change is not authorised by default.

---

3. How Wazuh analyses an event

A simplified Wazuh analysis flow is:

```
Raw event
  → pre-decoding
  → decoder matching and field extraction
  → rule evaluation
  → alert or no alert
  → alert file
  → Filebeat forwarding
  → indexer document
  → dashboard search and visualisation
```

3.1 Raw event

A raw event is the source record received by Wazuh.

Synthetic VCC example:

```
{
  "schema_version": "1.0",
  "event_id": "evt-auth-0009",
  "event_time": "2026-08-01T09:18:07Z",
  "pod_id": "pod-03",
  "event_type": "authentication",
  "action": "login",
  "outcome": "success",
  "user": "svc-backup",
  "source_ip": "203.0.113.44",
  "session_id": "sess-suspect-902",
  "synthetic": true
}
```

3.2 Pre-decoding

Pre-decoding identifies common header information in supported text formats, such as timestamps, hostnames and program names. Structured JSON may already carry these values as fields.

3.3 Decoding

A **decoder** identifies the event format and extracts named fields.

The VCC collector writes NDJSON. The Wazuh manager reads each JSON line using `log_format=json`, and Wazuh's JSON decoder can expose dynamic fields such as:

```
pod_id
event_type
outcome
user
source_ip
session_id
```

Decoder success does not equal detection

A record can be decoded correctly and still generate no alert because no rule condition was satisfied or because the matching rule's level is below the alert threshold.

3.4 Rule evaluation

A **rule** evaluates decoded information. A rule can match:

- one field or message pattern;
- several fields together;
- an event that follows an earlier rule match;
- a repeated event count within a time window;
- the same user, source, destination or another correlation value;

- child rules that inherit context from a parent rule.

The NeoLabs rules use custom IDs in the documented Wazuh custom range and currently cover synthetic authentication, access-control and telemetry-health events.

Rule result is a detection decision

When a rule matches, it tells the analyst that the configured condition was observed. It does not automatically prove malicious intent or successful impact.

3.5 Alert creation

Rules at or above the configured alert threshold create alert records. The alert includes Wazuh metadata such as:

- rule ID;
- rule level;
- rule description;
- rule groups;
- decoded fields;
- source location;
- manager or agent context;
- timestamp.

3.6 Indexing

Filebeat forwards alerts to the indexer. The indexer creates searchable documents, usually under an index pattern such as:

```
wazuh-alerts-*
```

3.7 Dashboard display

The dashboard queries indexed documents. Filters, selected time field, browser time zone and data view affect what is displayed.

4. Alerts and archives

4.1 Alert data

Alert data contains events that matched Wazuh rules at or above the configured alerting level.

Useful for:

- alert triage;
- rule and severity review;
- dashboards and common investigations;
- tracking detection volume.

Limitation: events that did not become alerts are absent.

4.2 Archive data

Wazuh archives can contain all received events when archive logging and indexing are enabled.

Useful for:

- finding context that did not trigger a rule;
- validating rule coverage;
- searching benign or low-level activity;
- investigating parser and detection gaps.

Costs and risks:

- much higher storage volume;
- more sensitive raw content;
- additional privacy and retention requirements;
- increased indexer workload.

NeoLabs will enable indexed archives only after resource, privacy and retention testing. The handbook must not instruct interns to assume archive data is always present.

---

5. Common ports and the NeoLabs restrictions

Official Wazuh deployments commonly use ports such as:

Port	Common purpose	NeoLabs student profile
`1514/TCP`	Wazuh agent event communication	Not published to the host by default

Port	Common purpose	NeoLabs student profile
`1515/TCP`	Agent enrolment service	Not published to the host by default
`514/UDP` or TCP	Syslog, where configured	Not published in the initial student profile
`55000/TCP`	Wazuh server API	Internal only; not host-published
`9200/TCP`	Wazuh indexer/OpenSearch API	Internal only; not host-published
`5601/TCP` inside container	Dashboard service	Mapped to loopback `8443` on the host

Why the restrictions exist

Publishing a service means making it reachable from the host network. Unnecessary exposure increases the attack surface and can reveal administrative APIs or indexed data.

The initial student stack uses a private Compose network for Wazuh components. Only the VCC collector has outbound egress to the approved telemetry endpoint.

---

6. NeoLabs container topology

```
Host workstation
│
├─ 127.0.0.1:8443
│    └─ wazuh.dashboard
│          ├─ internal TLS → wazuh.indexer
│          └─ internal TLS → wazuh.manager API
│
├─ wazuh.manager
│    ├─ reads /var/ossec/logs/vcc/vcc-events.ndjson
│    ├─ JSON decoding
│    ├─ NeoLabs custom rules
│    └─ Filebeat → wazuh.indexer
│
├─ wazuh.indexer
│    └─ internal-only indexed alert storage
│
└─ vcc.telemetry.collector
     ├─ outbound HTTPS/mTLS only
     ├─ server-issued pod scope
     ├─ synthetic-event validation
     └─ shared volume → manager input file
```

Persistence

Docker named volumes retain Wazuh configuration, index data, queues and dashboard state across ordinary stops. The guarded reset script removes volumes only after explicit destructive confirmation.

Generated files

Official Wazuh configuration and certificates are generated into ignored local directories. They are not committed because they include environment-specific cryptographic material and generated configuration.

---

7. VCC pod telemetry without pod access

The VCC model separates **telemetry access** from **infrastructure access**.

The intern receives:

- a local Wazuh environment;
- a short-lived enrolment token;
- a client certificate issued for the operator-recorded pod;
- synthetic events exported from that pod's scenario.

The intern does not receive:

- pod SSH access;
- an AWS role;
- database credentials;
- container access;
- private pod routes;
- a pod log-file mount;
- the ability to select another pod.

End-to-end scope enforcement

```
Operator assignment
  → one-time token
  → locally generated private key
  → certificate bound to assignment
  → Nginx mTLS verification
  → API lookup of active assignment
  → database query restricted to assigned pod
  → collector verifies response pod and every event pod
```

This is stronger than a shared password because each credential is unique, revocable and tied to an installation and assignment.

---

8. Local setup sequence

Run from `wazuh-stack/` after reading its README.

Step 1 — Generate local secrets

```
bash scripts/generate-local-secrets.sh
```

Creates `.env`, the local installation identifier and protected directories.

Step 2 — Receive operator material

The operator provides:

- the VCC HTTPS base URL;
- the public enrolment CA certificate;
- a short-lived token file.

The operator does not provide a pod password.

Step 3 — Prepare official Wazuh files

```
bash scripts/prepare-stack.sh
```

This checks out the exact official Wazuh Docker tag and commit, copies the single-node configuration, generates local indexer password hashes and creates Wazuh TLS certificates.

Step 4 — Run preflight

```
bash scripts/preflight.sh
```

This checks required tools, exact version pins, file permissions, placeholder secrets, dashboard binding, memory guidance and indexer kernel settings.

Step 5 — Enrol

```
bash scripts/enrol-vcc.sh --token-file /protected/path/bootstrap-token.txt
```

The private key remains on the workstation. The client sends no pod selector.

Step 6 — Start

```
bash scripts/start.sh
```

The script validates the Compose model, builds the collector, starts services and waits for health checks.

9. Health checks

Run:

```
bash scripts/health-check.sh
```

Expected output lists:

```
wazuh.manager
wazuh.indexer
wazuh.dashboard
vcc.telemetry.collector
```

Healthy but unenrolled

The collector can report a healthy waiting state before credentials are installed. This means the collector process is functioning; it does not mean VCC telemetry is arriving.

Manager healthy but no alerts

Possible reasons include:

- collector unenrolled or disconnected;
- no new telemetry;
- manager input file absent or unchanged;
- JSON decoding failure;
- rules not loaded;
- events matched only level-zero parent rules;
- Filebeat/indexer problem;
- dashboard time/filter problem.

Health is component-specific. One green component does not guarantee the complete pipeline works.

10. Basic data-flow validation

Use this order:

1. **Collector health:** Is it enrolled and polling successfully?
2. **Collector cursor:** Is the stored cursor advancing?
3. **Shared NDJSON file:** Are new valid lines present in the telemetry volume?
4. **Manager configuration:** Is the VCC localfile input loaded?
5. **Decoder test:** Does `wazuh-logtest` expose expected fields?

6. **Rule test:** Does the synthetic record match the intended rule?
7. **Manager alert file:** Was an alert written?
8. **Filebeat:** Is forwarding healthy?
9. **Indexer:** Is the cluster healthy and index writable?
10. **Dashboard:** Is the correct data view and absolute time range selected?

Do not skip directly to changing rules when the collector is not delivering data.

---

11. Common beginner misunderstandings

“The dashboard created the alert”

The manager’s rule engine created the alert. The dashboard displayed an indexed representation.

“The agent is active, so every log is collected”

Agent connectivity and source coverage are different questions.

“No alert means no event”

The event may have failed to generate, collect, decode, match, forward, index or appear under the selected filters.

“HTTP 200 proves the action was authorised”

A 200 response records a server outcome, not the legitimacy of the requester.

“Changing `POD_LABEL` changes my pod”

`POD_LABEL` is local display information. Authorised scope comes from the server-side assignment and certificate.

“A high rule level proves an incident”

Rule level expresses detection importance configured by the rule author. The analyst must still validate context and impact.

---

12. Guided exercise

Using the synthetic authentication dataset:

1. identify the raw JSON fields;

2. identify which fields the JSON decoder should expose;
3. identify the NeoLabs parent rule and relevant child rules;
4. predict which records should create alerts;
5. explain why a level-zero parent rule may not appear as an alert;
6. run the approved local rule test after the stack is prepared;
7. find the indexed alert in the dashboard;
8. record manager, indexer and dashboard evidence separately;
9. state one failure that could occur at each pipeline stage.

13. Review questions

1. What is the practical difference between the manager and indexer?
2. What does a decoder do?
3. What does a rule match prove?
4. Why can manager alerts exist without appearing in the dashboard?
5. What is the difference between alert and archive data?
6. Why are ports 55000 and 9200 not published in the student profile?
7. How does VCC provide pod telemetry without giving pod access?
8. Why is a unique client certificate stronger than one shared pod password?
9. What does a healthy but unenrolled collector mean?
10. List the ten data-flow validation stages in order.

Authoritative references

- Wazuh official documentation: architecture, Wazuh components, log data analysis and event logging.
- Wazuh official Docker repository, release `v4.14.7`.
- Wazuh official documentation: JSON decoder, custom rules, rule testing, Wazuh indices and API security.
- OpenSearch documentation: indices, mappings and Query DSL.
- Docker documentation: Compose networks, volumes, health checks and container security.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: docs/dashboard-tutorials/01-orientation-and-alert-investigation.md

Wazuh Dashboard Tutorial 01 — Orientation and First Alert Investigation

NeoLabs tested baseline: Wazuh 4.14.7
Tutorial version: 0.2-draft
Review date: 1 August 2026
Audience: SOC Level 1 interns

> Dashboard labels can change between releases. Verify the installed version under the dashboard **About** page before following a screenshot or menu path.

Learning objectives

By the end of this tutorial, a learner should be able to:

- identify the major Wazuh dashboard areas;
- distinguish platform health, agent status, indexed alerts and raw/archive events;
- set and verify the investigation time range;
- open an alert and inspect the event fields that support it;
- add filters, remove inherited filters and pivot to related activity;
- save an investigation view without embedding private information;
- recognise when a missing result may be a data or time-filter problem;
- record evidence and queries in the NeoLabs templates.

---

1. Before opening the dashboard

From `wazuh-stack/`, check local service health:

```
bash scripts/health-check.sh
```

Expected conditions:

- `wazuh.manager` is running and healthy;
- `wazuh.indexer` is running and healthy;
- `wazuh.dashboard` is running and healthy;

- `vcc.telemetry.collector` is either `healthy` or clearly marked `UNENROLLED` while waiting for authorised credentials.

Open the local dashboard address shown by the health script. The standard NeoLabs profile binds the dashboard to:

```
https://127.0.0.1:8443
```

The local browser may show a certificate warning while the workstation deployment uses generated training certificates. Confirm the address is the local loopback address and follow the programme's approved browser procedure. Never bypass a certificate warning for an unknown or public host.

Record the version

After signing in:

1. Open the upper-left navigation menu.
2. Open **About** in the Wazuh section.
3. Record the dashboard package version and revision in your query journal.
4. Confirm it matches the cohort's supported baseline.

Why this matters: a tutorial written for another release may use different names, fields or menu locations.

---

2. Understand the dashboard areas

The Wazuh home area groups information into broad security functions.

Endpoint security

Common views include:

- Configuration Assessment;
- Malware Detection;
- File Integrity Monitoring.

These views depend on the modules and telemetry configured for monitored endpoints. An empty panel may mean no findings, no compatible source, a disabled module or a time/filter issue.

Threat intelligence

Common views include:

- Threat Hunting;

- MITRE ATT&CK-related views;
- vulnerability and intelligence context where configured.

Threat Hunting is useful for reviewing security events and alerts beyond a single prebuilt dashboard.

Security operations

This area provides operational views such as:

- events and alerts;
- policy or compliance views;
- configuration and platform data.

Cloud security

Cloud dashboards appear when the relevant AWS, Azure, Microsoft or other integrations are configured and sending supported data.

Agents management

Agents management → Summary shows enrolled Wazuh agents and status categories such as:

- Active;
- Disconnected;
- Pending;
- Never connected.

Important VCC distinction: the NeoLabs pod feed is delivered through a pod-scoped telemetry collector and read by the local Wazuh manager. It is not permission to install or manage an agent inside a VCC pod. Do not interpret the absence of a pod-named Wazuh agent as proof that no pod telemetry exists.

Server management and app settings

These areas can show manager settings, API connections, configuration and component health. Some actions require administrator permissions and can affect the local deployment. Interns should follow the tutorial and avoid changing settings outside an assigned lab.

---

3. Alert data versus archive data

Wazuh commonly uses different index patterns for different purposes.

Index pattern	Typical purpose	SOC L1 caution
`wazuh-alerts-*`	Alerts generated when Wazuh rules reach the configured alert threshold	Contains detections, not every received event
`wazuh-archives-*`	All events received by the Wazuh server when archive indexing is enabled	Can be high-volume and may not be enabled in every deployment
`wazuh-monitoring-*`	Agent status information	Status history is not the same as security-event data
`wazuh-statistics-*`	Wazuh server performance and processing statistics	Useful for identifying dropped or delayed events

The NeoLabs starter investigation uses `wazuh-alerts-*`. Archive indexing will be enabled only after storage and privacy settings are approved and tested.

Why alerts are not complete evidence

A record can be absent from `wazuh-alerts-*` because:

- it did not match a rule;
- it matched a level below the alert threshold;
- the decoder failed;
- the record arrived outside the selected time range;
- the source never generated or delivered it.

When archive data is available, it helps investigate events that did not become alerts. When it is unavailable, state that limitation.

---

4. Start with the global time filter

A wrong time filter is one of the most common reasons analysts miss evidence.

1. Locate the time picker near the top-right of the relevant dashboard or Discover view.
2. Record the displayed time zone.
3. Choose an absolute range that includes the event's **event time**.
4. Expand the range slightly before and after the alert.
5. Apply the range and confirm the result count changes as expected.

Relative versus absolute time

- **Relative range:** "Last 15 minutes." Useful for live monitoring but changes as time passes.
- **Absolute range:** fixed start and end timestamps. Better for a report that another analyst must reproduce.

For submitted investigations, record the absolute UTC range even when you first used a relative range.

Event time versus ingest time

The indexed `timestamp` used by Wazuh may not be identical to a source's own `event_time` or the collector's `ingest_time`. Inspect all available timestamp fields before building a precise timeline.

---

5. Open an alert correctly

Use the assigned alert view or **Threat Hunting** view.

1. Set the time range.
2. Clear unrelated saved filters.
3. Find the target alert.
4. Expand the alert row or open its detail panel.
5. Inspect the full field list.
6. Record the rule ID, level, description, event time and affected entities.
7. Locate the original or full-log field where available.

Fields to identify in a NeoLabs VCC event

The exact path can vary after indexing, but look for the following source fields:

- `schema_version`;
- `event_id`;
- `event_time`;
- `ingest_time`;
- `pod_id`;
- `event_type`;
- `action`;
- `outcome`;
- `user` or other identity field;
- `source_ip`;
- `session_id`;
- `correlation_id`;
- `synthetic`.

Also record Wazuh-added fields:

- rule ID and level;
- rule groups;
- decoder name;
- manager or agent fields;
- indexed timestamp;

- source location.

Evidence question

For each displayed field ask:

- Did the source generate this value?
- Did a decoder derive it?
- Did enrichment add it?
- Could it be user-controlled?
- Does it directly support the alert description?

---

6. Add filters without losing context

Most dashboard event views let you filter by selecting a field value or adding a filter manually.

Useful first pivots include:

- `pod_id` for the server-issued assigned pod;
- `user` for the affected identity;
- `source_ip` for related activity from the same source;
- `session_id` for actions within one application session;
- `correlation_id` for records linked across components;
- rule ID for repeated detections;
- `event_type` and `outcome` for activity categories.

Include and exclude filters

An include filter narrows to matching records. An exclude filter removes matching records.

Before trusting the result count:

1. inspect every filter pill;
2. check whether a filter is disabled or inverted;
3. check whether the selected data view is correct;
4. record the filter and time range in the query journal.

Example investigation sequence

For a failure-to-success alert:

1. Filter to the assigned `pod_id`.
2. Filter to the affected `user`.
3. Expand the time range to 30 minutes.
4. Sort by event time ascending.

5. Identify failures and any success.
6. Remove the user filter and search the same `source_ip` for other targeted accounts.
7. Pivot from the success to its `session_id`.
8. Look for account, application and authorization events within that session.
9. Search telemetry-health events for the same time window.

Do not reproduce a denied cross-pod request. Document the denial already present in the synthetic evidence.

---

7. WQL is not the same as every dashboard search bar

Wazuh Query Language (WQL) is used in specialised Wazuh tabs and Wazuh server API filtering. Its general structure is:

```
field operator value
```

Common operators include:

```
=   equality
!=  inequality
>   greater than
<   less than
~   like/contains-style matching
```

WQL uses:

```
;   AND
,   OR
()  grouping
```

Example:

```
status=active;os.name=Ubuntu
```

Values containing spaces must be quoted. WQL is case-sensitive.

However, **Explore → Discover** and some alert-search views use index/search syntax provided by the Wazuh dashboard and OpenSearch layer rather than WQL. Do not paste a WQL expression into every search bar and assume the same meaning. The query reference identifies which language belongs to which interface.

---

8. Save a reproducible view

A saved search or dashboard view can preserve:

- selected fields;
- sort order;
- filters;
- query text;
- time range, depending on the interface.

Use a neutral name such as:

```
LAB01-authentication-timeline-student03
```

Do not put passwords, tokens, private URLs or personal information in saved-view names.

In the report, still write the query and time range. A saved object can be changed or deleted and may not be available to the reviewer.

---

9. Screenshot evidence

Take a screenshot only when it adds visual context. A strong screenshot should show:

- the relevant dashboard/view name;
- the absolute time range;
- active filters;
- essential fields or chart labels;
- enough context to understand what is being shown.

Before submission:

- crop unrelated browser content;
- hide passwords and private URLs;
- remove unrelated alerts and personal data;
- name the file using its evidence ID;
- record the screenshot in the evidence log;
- preserve the underlying event or query result when available.

A screenshot is not a substitute for searchable evidence.

---

10. Troubleshooting missing results

No alerts in the selected period

Check:

1. correct time range and time zone;
2. correct index/data view;
3. hidden filters;
4. Wazuh manager and indexer health;
5. collector status and cursor movement;
6. whether the event should have triggered a rule;
7. decoder and rule loading;
8. source record presence.

Fields are missing

Check:

- the expanded raw/full event;
- schema version;
- whether the JSON decoder recognised the event;
- recent field-name changes;
- index mappings;
- whether the source omitted the field.

Counts seem too high

Check:

- duplicate ingestion;
- grouped versus individual alerts;
- repeated rule matches for one event;
- the selected date histogram interval;
- whether several pods or sources are included.

Dashboard works but the VCC feed is empty

Check local collector health and enrolment state. Do not change pod identifiers or request parameters to test another pod. Escalate certificate, assignment or feed problems to the programme operator.

---

11. Guided exercise

Using Practice Lab 01:

1. Set an absolute UTC range covering the dataset.
2. Find the repeated authentication-failure alert.
3. Record its rule ID and source fields.
4. Filter by `svc-backup`.
5. Pivot to `203.0.113.44`.
6. Pivot to the successful session.
7. identify the authorization denial and account change;
8. identify the telemetry-health gap;
9. save a view;
10. complete the query journal and one evidence statement.

Required reflection

Explain why the successful login and later account change are stronger together than either event in isolation. Then explain how the telemetry gap limits conclusions about process activity.

---

12. Review questions

1. What is the difference between `wazuh-alerts-*` and `wazuh-archives-*`?
2. Why should an analyst use an absolute time range in a final report?
3. Name five useful VCC correlation fields.
4. Why might an event exist without an alert?
5. What is the difference between a WQL filter and a Discover search?
6. What should a screenshot contain to be useful evidence?
7. Why is an empty dashboard not proof that nothing happened?
8. Which step prevents an intern from accessing another pod’s telemetry?

Authoritative references

- Wazuh, *Navigating the Wazuh dashboard*.
- Wazuh, *Filtering data using Wazuh Query Language*.
- Wazuh, *Wazuh indexer indices*.
- Wazuh, *Log data analysis* and *Event logging*.
- Wazuh, *Wazuh agent connection*.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: docs/setup/WORKSTATION_COMPATIBILITY.md

NeoLabs SOC L1 Workstation Compatibility

Supported baseline

The student Wazuh stack is designed for a personally controlled workstation used only for authorised NeoLabs/RIL training. Run the compatibility check before downloading images or starting the stack:

```
bash wazuh-stack/scripts/compatibility-check.sh
```

A supported workstation should provide:

Requirement	Minimum	Recommended
CPU architecture	64-bit x86_64 or arm64	x86_64
CPU capacity	4 logical cores	6 or more logical cores
System memory	8 GiB	12–16 GiB
Free disk space	25 GiB	50 GiB
Container runtime	Docker Engine/Desktop	Current supported Docker release
Compose	Docker Compose v2	Current supported v2 release
Linux kernel setting	`vm.max_map_count=262144`	`262144` or higher

The stack also needs Python 3, OpenSSL and curl for validation and secure enrolment.

Platform guidance

Ubuntu or another current Linux distribution

This is the preferred student platform. Docker must be running, and the learner's account must be permitted to use it. Set the indexer mapping limit before startup when the compatibility check reports a failure:

```
sudo sysctl -w vm.max_map_count=262144
```

Make the setting persistent using the operating system's approved sysctl configuration process.

Windows 11 with WSL2

Use an Ubuntu WSL2 distribution with Docker Desktop's WSL integration enabled. Store the repository inside the Linux filesystem, such as `~/neolabs-soc1-toolkit`, rather than under `/mnt/c/`; Linux filesystem storage provides more predictable permissions and container performance.

Do not run the stack directly from Git Bash, MSYS or Cygwin. Those shells do not provide the Linux permission and volume behaviour expected by the scripts.

macOS on Intel

Docker Desktop is supported when the machine meets the memory and disk requirements. Allocate enough Docker Desktop memory for the indexer, manager, dashboard and telemetry collector.

macOS on Apple Silicon

The scripts and learning materials work on arm64, but each pinned Wazuh container release must publish a compatible arm64 image. The compatibility check therefore reports Apple Silicon as a review warning rather than an unconditional pass. Use an x86_64 Linux or WSL2 workstation when the pinned release does not provide the required image architecture.

Unsupported configurations

The following configurations are outside the supported student baseline:

- 32-bit operating systems;
- Docker Toolbox or legacy Compose v1;
- production servers or shared company infrastructure;
- public cloud hosts exposed directly to the internet;
- systems with less than 8 GiB memory;
- systems where the learner does not control local Docker access;
- mobile devices and browser-only coding environments.

Pre-start checklist

1. Run `compatibility-check.sh` and resolve every failure.
2. Confirm that the repository is on a local, trusted filesystem.
3. Copy `.env.example` to `.env` and generate local secrets.
4. Run `preflight.sh` and `prepare-stack.sh`.
5. Start the stack and run `health-check.sh`.
6. Complete VCC enrolment only with a private, operator-issued token.

A warning may be accepted only when its risk is understood and documented. A failure must be corrected before the learner starts the Wazuh stack.

Source: docs/setup/BACKUP_AND_RECOVERY.md

NeoLabs SOC L1 Backup and Recovery

Purpose

The student Wazuh environment contains locally generated investigation data, dashboards, indexer data and manager state. A workstation failure should not require a learner to rebuild every investigation from the beginning.

The toolkit therefore provides a guarded Docker-volume backup and restore process. It is designed for local training data, not for production disaster recovery.

Security boundary

A toolkit backup deliberately excludes:

- `.env`;
- VCC bootstrap tokens;
- client private keys;
- client certificates and CA trust files;
- enrolment responses;
- private VCC endpoints;
- production data or credentials.

After restoring, the learner must complete a fresh operator-approved enrolment. This prevents copied backups from becoming reusable VCC access packages.

Create a backup

From the repository root:

```
bash wazuh-stack/scripts/backup.sh
```

The script performs the following actions:

1. confirms that Docker, Compose and the local `.env` file are available;
2. discovers the named volumes declared by the Wazuh Compose file;
3. stops the running stack to obtain a consistent point-in-time snapshot;
4. creates one compressed archive per existing volume;
5. calculates SHA-256 checksums;
6. writes a manifest and recovery notice;
7. restarts the stack unless `--no-restart` was supplied.

Use a specific destination when required:

```
bash wazuh-stack/scripts/backup.sh --output /secure/local/path/neolabs-backup
```

Keep the backup on encrypted, personally controlled storage. Do not upload it to a public repository or share it in Slack or WhatsApp.

Verify a backup

Always verify a backup before relying on it:

```
bash wazuh-stack/scripts/verify-backup.sh /path/to/backup
```

Verification checks the manifest version, checksum file, archive readability, presence of at least one volume and absence of common credential filenames.

Restore a backup

A restore replaces the contents of the matching Wazuh volumes. Stop the stack and confirm the backup path before continuing:

```
bash wazuh-stack/scripts/stop.sh
bash wazuh-stack/scripts/restore.sh /path/to/backup --force
```

The restore script:

- verifies checksums before modifying volumes;
- accepts only volume names declared in the current Compose file;
- refuses to run while stack services are active;
- recreates and repopulates the declared volumes;
- removes stale local VCC collector scope and cursor state;
- does not restore enrolment credentials.

After restoration:

```
bash wazuh-stack/scripts/compatibility-check.sh
bash wazuh-stack/scripts/start.sh
bash wazuh-stack/scripts/health-check.sh
```

Then request a new enrolment token from the programme operator and complete the normal enrolment workflow.

Rehearsal

The repository CI performs a synthetic Docker-volume recovery rehearsal using:

```
bash wazuh-stack/tests/backup-restore-rehearsal.sh
```

The rehearsal creates a temporary volume, writes a synthetic marker, archives it, verifies its checksum, deletes and recreates the volume, restores the archive and confirms that the marker survived. It never reads the learner's Wazuh data.

Recovery limitations

A successful archive verification does not prove that every future Wazuh release can read data created by an older release. Restore into the same pinned toolkit version first. Complete a documented Wazuh upgrade only after the restored stack is healthy.

Backups are not a substitute for GitHub submissions. Investigation reports, evidence logs and query journals should still be committed to the approved assignment repository after removing credentials, private URLs and sensitive evidence.

Source: troubleshooting/WAZUH_SETUP_AND_TROUBLESHOOTING_GUIDE.md

NeoLabs Wazuh Setup and Troubleshooting Guide

Tested baseline: Wazuh 4.14.7
Guide version: 0.2-draft
Review date: 1 August 2026
Scope: Learner-owned workstation and authorised VCC synthetic telemetry only

> Troubleshoot from the source toward the dashboard. Changing several settings at once can hide the real cause and create a second problem.

1. Golden troubleshooting sequence

```
Host requirements
  → Docker daemon
  → local files and permissions
  → generated Wazuh configuration
  → container startup
  → component health
  → VCC enrolment and mTLS
  → collector output
  → manager file monitoring
  → decoding and rules
  → Filebeat/indexer
  → dashboard data view, time and filters
```

Record every command and result in the query journal. Remove credentials and private URLs before submitting evidence.

---

2. Safe commands first

Run from `wazuh-stack/`.

Preflight

```
bash scripts/preflight.sh
```

Service status

```
bash scripts/health-check.sh
```

Compose process list

```
docker compose --env-file .env ps
```

Recent service logs

```
docker compose --env-file .env logs --since=10m \
  wazuh.manager wazuh.indexer wazuh.dashboard vcc.telemetry.collector
```

Before sharing logs, review them for:

- private VCC endpoints;
- usernames or personal information;
- certificate details;
- environment values;
- raw application data outside the assignment.

Do not use `docker inspect` to publish complete environment blocks.

Part I — Host and Docker problems

3. `docker: command not found`

Meaning

Docker Engine or Docker Desktop is not installed, or the command is not on the current PATH.

Checks

```
docker --version
docker compose version
```

Resolution

Install Docker from the official Docker instructions for the learner’s operating system. Use the Compose plugin, not an unverified third-party package.

Escalate when

- the learner does not have permission to install system software;
- the device is managed by an organisation;
- hardware virtualisation is disabled and requires administrator access.

4. Docker daemon not running

Typical message:

```
Cannot connect to the Docker daemon
```

Checks

```
docker info
```

On Docker Desktop, confirm the application is running. On Linux, an authorised administrator may check the Docker service.

Caution

Do not solve this by exposing an unauthenticated Docker TCP socket. Docker daemon access provides extensive control over the local host.

5. Permission denied accessing Docker

Typical Linux message:

```
permission denied while trying to connect to the Docker daemon socket
```

The user lacks access to the local Docker daemon.

Follow the approved system-administration procedure. Membership in the Docker group is effectively privileged on that workstation and should not be treated as a harmless application permission.

6. Insufficient memory or storage

Possible symptoms:

- indexer repeatedly restarts;
- dashboard remains unavailable;
- containers are killed with exit code 137;
- searches are extremely slow;
- disk watermark or read-only index errors appear.

Checks

```
docker stats --no-stream
docker system df
df -h
```

The all-in-one training baseline should have approximately 4 CPU cores, 8 GiB RAM and 50 GB available storage.

Resolution

- stop unrelated heavy applications;
- allocate enough resources to Docker Desktop;
- free approved local storage;
- do not delete Wazuh volumes unless the reset procedure is authorised;
- report repeated disk-watermark errors to the mentor.

7. `vm.max_map_count` too low

The indexer may fail with a message related to virtual memory areas.

Check

```
cat /proc/sys/vm/max_map_count
```

Required baseline:

```
262144 or higher
```

Use the operating-system-specific official OpenSearch/Wazuh guidance. A learner should not change shared or managed systems without permission.

Part II — Local files and preparation

8. Missing `.env`

Typical preflight error:

```
Missing wazuh-stack/.env
```

Run:

```
bash scripts/generate-local-secrets.sh
```

The script refuses to overwrite an existing `.env` because that could destroy valid local credentials or configuration.

9. Placeholder password remains

Preflight rejects values beginning with:

```
CHANGE_ME
```

Use the secret-generation script. Do not replace placeholders with a short shared classroom password.

10. `.env` permissions are too broad

Expected mode:

```
600
```

Check:

```
stat -c '%a %n' .env
```

Fix on a compatible Unix-like system:

```
chmod 600 .env
```

On platforms that do not expose Unix permissions in the same way, follow the tested platform-specific cohort guidance.

11. `prepare-stack.sh` cannot verify the Wazuh commit

The script checks that the official tag resolves to the exact reviewed commit.

Do not bypass the comparison. Possible causes include:

- the `.env` pin was edited;
- an incomplete or incorrect tag was configured;
- the local upstream checkout is damaged;
- the reviewed baseline has changed.

Safe recovery

Remove only the ignored upstream state directory after confirming no local evidence is stored there, then rerun preparation. Do not change the expected commit to make the error disappear without technical review.

12. Certificate generation fails

Possible causes:

- Docker cannot pull the official generator image;
- the generated directory has incorrect ownership;
- stale generated files conflict;
- insufficient disk space;
- network access to the container registry is unavailable.

Checks

```
docker pull wazuh/wazuh-certs-generator:0.0.2
ls -la generated
```

Use the exact image referenced by the reviewed official Wazuh release. Do not substitute an unknown certificate generator.

Part III — Container startup

13. Compose configuration error

Validate without starting:

```
docker compose --env-file .env config --quiet
```

Common causes:

- missing environment variables;
- malformed YAML;
- missing generated bind-mount files;
- a host path created as a directory when a file was expected;
- unsupported Compose version.

14. Dashboard port already in use

Typical error:

```
address already in use
```

Check which approved local process uses the port. Change `WAZUH_DASHBOARD_PORT` to another unused high port only if the cohort guidance permits it.

Keep:

```
WAZUH_DASHBOARD_BIND=127.0.0.1
```

Do not change the bind address to `0.0.0.0` merely to fix a local browser problem.

15. Manager unhealthy

Check:

```
docker compose --env-file .env logs --since=10m wazuh.manager
```

Possible causes:

- invalid `ossec.conf` XML;
- unreadable mounted certificate;
- indexer connection failure;
- invalid local rules;
- volume permission issue;
- resource exhaustion.

Rule/config validation

Inspect manager startup messages for the exact file and line. Do not delete the rule file blindly. Restore the reviewed file or test the specific change.

16. Indexer unhealthy

Check:

```
docker compose --env-file .env logs --since=10m wazuh.indexer
```

Common causes:

- `vm.max_map_count` too low;
- memory exhaustion;
- certificate mismatch;
- invalid internal-user password hashes;
- corrupted or incompatible data volume;
- disk watermark.

Do not delete `wazuh-indexer-data` as a first response. It contains the local searchable investigation data.

17. Dashboard unhealthy

Check:

```
docker compose --env-file .env logs --since=10m wazuh.dashboard
```

Common causes:

- indexer not healthy;
- wrong indexer password;
- wrong Wazuh API password;
- missing certificate mount;
- dashboard waiting for dependencies;
- insufficient memory.

Follow dependency order: indexer and manager must be healthy before expecting the dashboard to become ready.

Part IV — Browser and login

18. Browser cannot open the dashboard

Confirm:

```
bash scripts/health-check.sh
```

Then use exactly the address printed by the script.

Checks:

- correct port;
- `https`, not `http`;
- loopback address;
- no corporate proxy rewriting local traffic;
- dashboard container healthy.

19. Certificate warning

The local Wazuh dashboard uses generated training certificates. Verify:

- the address is the local loopback address;
- the certificate belongs to the local generated stack;
- the programme-approved browser procedure allows proceeding.

Never generalise this behaviour to public or unknown websites.

20. Dashboard password rejected

Do not paste the password into screenshots or chat.

Possible causes:

- `.env` was regenerated after the indexer security configuration was prepared;
- preparation was run with one password and startup with another;
- browser password manager inserted an old value;
- local index data belongs to a previous configuration.

The local `.env`, generated `internal_users.yml` and running containers must belong to the same preparation cycle. Use the documented reset/rebuild procedure only after preserving required evidence.

Part V — VCC enrolment

21. Enrolment base URL is empty

Set the operator-provided HTTPS base URL in `.env`:

```
VCC_ENROLMENT_BASE_URL=https://<approved-host>:8443
```

Do not add a pod path or query parameter.

22. Enrolment CA certificate missing

Expected path:

```
secrets/vcc/enrolment-ca.crt
```

The CA must come from the NeoLabs operator through the approved channel. Do not download or replace it from an unverified message or website.

23. TLS verification failed during enrolment

Possible causes:

- incorrect CA certificate;
- hostname does not match the server certificate;
- connecting to the wrong port or host;
- system clock incorrect;
- intercepting proxy;
- expired server certificate.

Do not disable TLS verification. Escalate the hostname and certificate error to the operator.

24. Bootstrap token rejected

The client intentionally returns a general message for invalid, expired, consumed or mismatched tokens.

Possible causes:

- token expired;
- token was already used;
- a replacement token invalidated it;
- assignment was revoked;
- whitespace or line wrapping altered the token;
- the token belongs to another installation workflow.

Request a new token through the approved channel. Do not ask another intern for theirs.

25. Existing local enrolment detected

The client refuses to overwrite active material.

Correct procedure:

1. contact the operator;
2. identify the existing credential ID from local enrolment metadata without publishing it;
3. obtain server-side revocation;
4. confirm whether the assignment changes;
5. rerun enrolment with explicit replacement only after approval.

Deleting the certificate locally does not revoke it on the server.

26. Enrolment succeeds but collector shows authentication error

Possible causes:

- credential revoked after issuance;
- certificate expired;
- telemetry URL changed;
- installation ID file changed;
- mTLS Nginx route not configured correctly;
- client and server clocks differ significantly.

Do not regenerate the installation ID. Preserve the local health record and ask the operator to check the credential and audit events.

Part VI — Collector problems

27. Collector status `unenrolled`

This is expected before valid endpoint and certificate files exist.

Check:

```
ls -l secrets/vcc
cat state/collector-health.json
```

Do not print private key contents.

28. Collector status `connection_error`

Possible causes:

- endpoint unavailable;
- DNS failure;
- firewall or proxy block;
- server certificate verification failure;
- timeout.

Use only non-secret connectivity checks approved by the operator. Do not use insecure curl flags against the VCC endpoint in submitted work.

29. Collector status `authentication_error`

The API returned HTTP 401 or 403.

Likely causes:

- missing or invalid client certificate;
- revocation;
- installation ID mismatch;
- assignment revoked;
- certificate expired.

This requires operator-side audit review. Editing `POD_LABEL` cannot fix authentication.

30. Collector status `validation_error`

The collector rejected the response.

Possible causes:

- missing required field;
- `synthetic` is not exactly `true`;
- event `pod_id` differs from the server-issued pod;
- response omitted `X-VCC-Pod-ID`;
- invalid NDJSON;
- oversized response;
- server-issued pod changed without credential reset.

Treat a wrong-pod event as a security stop condition. Preserve the private evidence and notify the programme operator immediately.

31. Cursor not moving

A cursor can remain unchanged when no new events exist. Check:

- collector health says the poll succeeded;
- event count returned was zero;
- assignment scenario is active;
- cursor file modification time;
- operator exporter health.

Do not delete the cursor to force replay unless the operator approves. Replaying a large range can duplicate local analysis work.

Part VII — Manager ingestion and detection

32. Collector writes events but Wazuh shows none

Validate the shared data path inside containers without exposing event content unnecessarily.

Questions:

1. Is the collector output file present?
2. Does the manager mount the same named volume?
3. Does the manager configuration monitor the exact path?
4. Is `log_format=json` set?
5. Did the manager reload the configuration?
6. Are events valid one-object-per-line NDJSON?

33. JSON decoder does not expose fields

Use `wazuh-logtest` in the local manager with one approved synthetic record.

Check:

- valid JSON;
- no extra prefix before `{`;
- field types are expected;
- schema version is supported;
- nested fields match the rule paths;
- the event fits within size limits.

A JSON record being syntactically valid does not guarantee its schema matches the rules.

34. Rule does not match

Check:

- parent rule matched;
- field name and case;
- regex anchors;
- expected string versus Boolean representation;
- custom rule file loaded;
- rule ID does not collide;
- level and grouping;
- correlation timeframe and frequency;
- correct static/dynamic correlation field.

Test one simple event first, then the sequence.

35. Repeated-event rule does not trigger

Correlation rules require events to arrive within the configured timeframe and satisfy grouping conditions.

Check:

- event ingestion order;
- Wazuh analysis timestamp behaviour;
- same-user or same-field values are populated consistently;
- frequency count includes the intended parent rule;
- the test session is not affected by prior cached events;
- malformed or rejected events did not break the sequence.

36. Alert exists in manager but not dashboard

Check:

1. manager alert file;
2. Filebeat logs;
3. certificate and indexer connectivity;
4. indexer health;
5. index existence;
6. dashboard data view;
7. absolute time range;
8. hidden filters.

This indicates the detection stage worked and the problem is later in the pipeline.

Part VIII — Indexer and dashboard investigation problems

37. Indexer cluster red or read-only

Possible causes:

- disk pressure;
- unavailable shard;
- corrupted volume;
- memory instability;
- incompatible restored data.

Do not run destructive index commands as a learner. Preserve logs and escalate.

38. Query returns zero results unexpectedly

Check:

- correct index pattern;
- absolute UTC range;
- event versus ingest timestamp;
- exact field path;
- keyword versus analysed mapping;
- active dashboard filters;
- pod and synthetic values;
- alert level and archive availability.

Record the zero-result query and the source-health checks before calling it evidence.

39. Fields appear under a different path

Wazuh and index mappings may nest source fields under `data` or another source-specific object.

Open a real event, inspect the field list and use the actual indexed path. Update the query journal. Do not silently change the training rule without confirming the decoder and mapping.

40. Times appear shifted

Check:

- browser time-zone setting;
- dashboard advanced settings;
- source `event_time`;
- indexed `timestamp`;
- collector `ingest_time`;
- host clock.

Build the report timeline in UTC and document conversions.

Part IX — Reset and recovery

41. Stop without deleting data

```
bash scripts/stop.sh
```

42. Destructive reset

First run without confirmation to display the warning:

```
bash scripts/reset.sh
```

Then, only after preserving required work:

```
bash scripts/reset.sh --confirm-destroy-local-data
```

This removes Wazuh volumes, generated configuration and local telemetry state. It retains enrolment material unless the additional approved flag is used.

43. Removing enrolment material

Server-side revocation must happen first. Then:

```
bash scripts/reset.sh \
  --confirm-destroy-local-data \
  --include-enrolment
```

Confirm revocation with the operator. Local deletion alone is not a security control.

Part X — Escalation package

When troubleshooting cannot be completed safely, provide:

```
Workstation OS and version:
Docker and Compose versions:
Wazuh version:
Exact failing step:
First error time in UTC:
Service health summary:
Relevant redacted error lines:
Commands already run:
Whether the system ever worked:
Recent approved changes:
Assigned pod as shown by local state:
Credential ID reference, not private certificate/key:
Impact on investigation:
```

Do not include:

- `.env` contents;
- tokens;
- private keys;
- complete certificate dumps;
- private VCC URLs in public issues;
- unrelated student or pod evidence.

Quick decision tree

```
Dashboard unavailable?
  ├─ Compose invalid → fix local configuration
  ├─ Indexer unhealthy → host/kernel/memory/cert/storage checks
  ├─ Manager unhealthy → XML/rule/cert/indexer checks
  └─ Dashboard only unhealthy → API/indexer/password/cert checks

Dashboard available but no VCC events?
  ├─ Collector unenrolled → complete approved enrolment
  ├─ Authentication error → operator credential/audit review
  ├─ Validation error → security stop; check wrong-pod/schema response
  ├─ No collector output → exporter/feed/connectivity review
  ├─ Output exists, no decoded event → manager localfile/JSON review
  ├─ Decoded event, no alert → rule/level/correlation review
  ├─ Manager alert exists, no index → Filebeat/indexer review
  └─ Indexed alert exists, not visible → data view/time/filter review
```

Authoritative references

- Wazuh official documentation: Docker deployment, component requirements, server logs, JSON decoder, custom rules, `wazuh-logtest`, indexer and dashboard troubleshooting.
- OpenSearch documentation: bootstrap checks, disk watermarks, cluster health and mappings.
- Docker documentation: daemon, Compose, resource controls, volumes and security.
- `wazuh-stack/README.md`.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.

Source: wazuh-stack/README.md

NeoLabs Student Wazuh Stack

Purpose

This directory provides a repeatable local Wazuh manager, indexer and dashboard for authorised NeoLabs SOC Level 1 training. A separate hardened collector can receive only the synthetic telemetry issued to the learner's assigned VCC pod.

The baseline follows the official Wazuh single-node container topology and pins:

- Wazuh release `4.14.7`;
- official Docker tag `v4.14.7`;
- verified upstream commit `adcc5b57d2f7edfcbe6c399272dc76fbdf12b623`.

Changing the version requires release-note review, regenerated configuration, rule tests, Compose validation and a new recorded review date.

Current status

The stack is a reviewed **Version 1 release candidate** on the toolkit feature branch. The local manager, indexer, dashboard, collector, enrolment client, health checks, reset controls, backup/restore workflow, compatibility assessment, starter rules and CI tests are implemented.

The corresponding isolated VCC control-plane rehearsal passed:

- certificate-signing request exchange;
- single-use bootstrap-token enforcement;
- two separate intern-to-pod assignments;
- server-enforced pod isolation;
- rejection of client-selected pod scope;
- credential revocation;
- assignment revocation.

The repository also passes collector unit tests, Compose validation, secret-boundary checks and a synthetic Docker-volume backup/restore rehearsal. Automated workstation validation runs on Linux CI. WSL2 and macOS deployment profiles are documented in `../docs/setup/WORKSTATION_COMPATIBILITY.md`, but should still be checked on the actual cohort machines during controlled rollout.

This branch has not been merged or deployed. Students should use it only after NeoLabs operator approval and receipt of their individual enrolment details.

Required workstation capacity

Run the automated assessment first:

```
bash scripts/compatibility-check.sh
```

For the all-in-one Wazuh topology, plan for approximately:

- 4 CPU cores;
- 8 GiB RAM minimum, with 12–16 GiB recommended;
- 25 GiB free storage minimum, with 50 GiB recommended;
- Docker Engine or Docker Desktop with Compose v2;
- Linux, WSL2 or a reviewed Docker Desktop environment;
- `vm.max_map_count` of at least `262144` where the host exposes that setting;
- Python 3, OpenSSL and curl.

Smaller systems may start but can become unstable or too slow for investigations.

Security design

Network exposure

- The Wazuh indexer is not published to the host.
- The Wazuh server API is not published to the host.
- The dashboard binds to `127.0.0.1:8443` by default.
- Wazuh components use an internal-only Compose network.
- Only the VCC telemetry collector receives an outbound network path.

Pod isolation

The learner does not choose an authorised pod by editing `POD_LABEL`, a URL or a request parameter.

1. A programme operator records the intern-to-pod assignment in the VCC control plane.
2. The operator issues a short-lived, single-use bootstrap token.
3. The enrolment client creates a local private key and sends only a certificate signing request.
4. The control plane consumes the token and issues a client certificate bound to the recorded assignment.
5. Nginx verifies the client certificate for every telemetry request.
6. The control plane derives pod scope from the active certificate and assignment.
7. The collector rejects any event whose `pod_id` differs from the server-issued pod.
8. Reassignment requires server-side revocation and explicit local re-enrolment.

A shared pod password is intentionally not used.

Files that must remain private

Never commit or send through a public channel:

- `.env`;
- bootstrap token files;
- `secrets/vcc/client.key`;
- issued client certificates when programme policy treats them as confidential;
- VCC private URLs;
- `state/enrolment.json`;
- raw evidence containing personal information or another pod's data;
- generated backups.

The operator-issued enrolment CA certificate is public-key material, but it must still be delivered through an approved channel so the learner can verify that it belongs to the real VCC lab.

Setup workflow

Run commands from `wazuh-stack/`.

1. Check the workstation

```
bash scripts/compatibility-check.sh
```

Resolve every failure before continuing. Platform-specific guidance is available in `../docs/setup/WORKSTATION_COMPATIBILITY.md`.

2. Generate local secrets

```
bash scripts/generate-local-secrets.sh
```

This creates `.env`, an installation identifier and protected local directories. Password values are not printed.

3. Configure the enrolment endpoint

The operator supplies:

- the HTTPS enrolment base URL;
- the VCC enrolment CA certificate;
- a short-lived bootstrap token file when the intern is ready to enrol.

Place the CA at:

```
secrets/vcc/enrolment-ca.crt
```

Set the operator-provided URL in `.env`:

```
VCC_ENROLMENT_BASE_URL=https://soc.lab.example.invalid:8443
```

Do not add a pod ID to this URL.

4. Prepare the pinned Wazuh configuration

```
bash scripts/prepare-stack.sh
```

The script:

- clones the official `wazuh/wazuh-docker` repository into ignored local state;
- checks out the exact pinned tag;
- verifies the full expected commit SHA;
- copies the official single-node configuration;
- generates local indexer password hashes;
- generates the Wazuh TLS certificate set;
- adds the NeoLabs VCC NDJSON input configuration.

No Wazuh service is started by this step.

5. Run preflight validation

```
bash scripts/preflight.sh
```

Preflight checks Docker, Compose, local file permissions, placeholder passwords, pinned versions, dashboard binding, memory guidance and `vm.max_map_count` where available.

6. Enrol to the assigned VCC pod

Protect the operator-issued token file:

```
chmod 600 /path/to/bootstrap-token.txt
```

Then run:

```
bash scripts/enrol-vcc.sh --token-file /path/to/bootstrap-token.txt
```

The client does not send a learner-selected pod. It stores the server-issued pod and credential metadata locally without printing private key or certificate contents.

7. Start and validate the stack

```
bash scripts/start.sh
```

The startup script validates the generated files, checks the Compose model, builds the collector, starts services and waits for health checks.

View current health later with:

```
bash scripts/health-check.sh
```

The collector is considered healthy while waiting for enrolment, but Wazuh will not receive VCC telemetry until valid credentials and an endpoint exist.

8. Back up local Wazuh data

```
bash scripts/backup.sh
```

The stack is stopped briefly for a consistent archive and restarted afterward. Backups exclude `.env`, VCC tokens, private keys, certificates and private endpoints. Verify a backup with:

```
bash scripts/verify-backup.sh /path/to/backup
```

The complete recovery procedure is documented in `../docs/setup/BACKUP_AND_RECOVERY.md`.

9. Stop without deleting data

```
bash scripts/stop.sh
```

This retains Wazuh volumes, local telemetry and enrolment credentials.

10. Restore local Wazuh data

Stop the stack, verify the selected backup and restore only after confirming the destructive replacement:

```
bash scripts/restore.sh /path/to/backup --force
```

Credential material is intentionally not restored. Complete a new operator-approved enrolment after recovery.

11. Destructive local reset

Review the warning first:

```
bash scripts/reset.sh
```

To delete local Wazuh data and generated configuration:

```
bash scripts/reset.sh --confirm-destroy-local-data
```

Removing enrolment material additionally requires confirmed server-side revocation:

```
bash scripts/reset.sh --confirm-destroy-local-data --include-enrolment
```

Deleting local certificate files alone does not revoke the server credential.

VCC telemetry format

The collector accepts newline-delimited JSON and requires at least:

```
{
  "schema_version": "1.0",
  "event_id": "evt-example-001",
  "event_time": "2026-08-01T09:14:21Z",
  "pod_id": "pod-03",
  "event_type": "authentication",
  "synthetic": true
}
```

The collector fails closed when:

- the event is not marked synthetic;
- required fields are missing;
- an event carries a different pod from the server-issued response header;
- the server-issued pod changes without credential reset;
- TLS verification fails;
- the response exceeds the configured size or event-count limit.

Initial NeoLabs rules

`config/rules/neolabs_vcc_rules.xml` contains training detections for:

- authentication failure;
- repeated failures by account;
- repeated failures by source;
- successful authentication;

- success following earlier failures;
- sensitive account changes;
- protected access-control denials;
- telemetry quality and availability problems.

These are starter rules, not proof of compromise. Analysts must inspect the underlying records, context and visibility limitations.

Troubleshooting order

When events are missing, check in this order:

1. local Compose and container health;
2. enrolment state and certificate expiry;
3. collector health JSON and cursor movement;
4. HTTPS/mTLS connectivity without printing secrets;
5. presence of records in the shared `vcc_telemetry` volume;
6. Wazuh manager file monitoring;
7. JSON decoding and required fields;
8. rule loading and `wazuh-logtest` validation;
9. indexer health and dashboard time filters.

Use `../troubleshooting/WAZUH_SETUP_AND_TROUBLESHOOTING_GUIDE.md` for the full decision tree.

References

- Official Wazuh documentation and `wazuh/wazuh-docker` release repository.
- Docker Compose and Docker Engine security documentation.
- `../research/AUTHORITATIVE_SOURCE_REGISTER.md`.
- VCC control-plane architecture and implementation in the private VCC Security Lab repository.

Source: templates/evidence-log-template.md

NeoLabs SOC Evidence Log Template

> Record evidence used in an authorised investigation. This template is for training and case discipline; it does not replace organisational forensic procedures or legal chain-of-custody requirements.

Case information

Field	Entry
Case / assignment ID	
Analyst	
Assigned pod	
Investigation start	YYYY-MM-DD HH:MM UTC
Report path / link	

Evidence register

Evidence ID	Date/ time collected (UTC)	Event time range	Source system	Evidence type	Collection method / query	Original location	File or record hash, when applicable	Handling / redaction note	Releva
EV-001				Alert / raw event / export / screenshot / config / owner confirmation					

Evidence-quality checks

For each important item, consider:

- Was the source operating during the event period?
- Is the timestamp event time, ingest time or alert time?

- Is the time zone known?
- Could the record be duplicated, delayed or truncated?
- Did a decoder or parser alter the displayed fields?
- Is the value source-generated, user-controlled or enrichment data?
- Is the evidence complete enough for the conclusion?
- Was sensitive data redacted without removing necessary meaning?

Evidence statements

Use one statement per important claim.

EV-___

Observed fact:

Source and time:

What this evidence supports:

What this evidence does not prove:

Quality or visibility limitation:

Related evidence:

Transfer or review record

Date/time UTC	Evidence ID(s)	From	To / reviewer	Purpose	Method	Confirmation

Final checks

- [ ] Every report fact points to an evidence ID or clearly identified source.
- [ ] No credential, private key or enrolment token is included.
- [ ] Personal or cross-pod information is removed or escalated rather than published.
- [ ] Screenshots show the required context and do not replace available raw records.
- [ ] UTC conversions are documented.
- [ ] Negative findings include the source, query and time range.

Source: templates/query-journal-template.md

NeoLabs SOC Query Journal Template

> Record searches as they are performed so another analyst can reproduce the investigation. Replace secrets and private endpoints with approved references; never paste enrolment tokens or private keys.

Case information

Field	Entry
Case / assignment ID	
Analyst	
Assigned pod	
Investigation date	
Primary alert	

Query register

Query ID	Time run (UTC)	Platform / source	Exact query or filter	Event-time range	Result count	Important result or negative finding	Evidence IDs	Next pivot
Q-001		Wazuh / OpenSearch / local tool						

Detailed query record

Q-___

Question being tested:

Data source and index/view:

Exact query/filter/command:

Time field used: Event time / ingest time / other
Time range:
Fields displayed or exported:
Result summary:
Relevant evidence IDs:
Limitations:
Decision / next query:

Query-quality checks

- [ ] The query uses the intended field rather than only free-text search.
- [ ] Exact and analysed fields are distinguished where applicable.
- [ ] The event-time field and time zone are recorded.
- [ ] A zero-result search was checked against source health and retention.
- [ ] Filters inherited from a dashboard or saved view are recorded.
- [ ] Wildcards and broad searches are narrowed before drawing conclusions.
- [ ] Commands were run only against synthetic data or explicitly authorised systems.
- [ ] Output containing sensitive values was redacted before submission.

Investigation summary

Most useful query:

Most important negative finding:

Visibility gap discovered:

Queries recommended for higher-tier review:

Source: templates/incident-report-template.md

NeoLabs SOC Incident Report Template

> Use for authorised VCC exercises and approved synthetic investigations. Replace instructional text before submission. Do not include credentials, private keys, enrolment tokens or unredacted personal information.

1. Report control

Field	Entry
Report title	
Case / assignment ID	
Analyst name	
Track and cohort	SOC Level 1 /
Assigned pod	
Report version	1.0
Prepared at	YYYY-MM-DD HH:MM UTC
Reviewer	
Classification	Training use / confidential programme material as directed

2. Executive summary

Write 3–6 sentences for a reader who may not know Wazuh or the scenario. State:

- what triggered the investigation;
- the affected account, service or asset;
- the most important confirmed facts;
- the current classification and confidence;
- the recommended next action.

Do not include unsupported claims or long raw-log extracts.

3. Alert and detection information

Field	Entry
Alert name	
Alert / rule ID	
Detection source	
Alert creation time	
Earliest confirmed event time	
Tool-assigned severity	
Analyst-assigned priority	
Relevant ATT&CK behaviour	Optional; explain mapping

4. Scope

Affected identities

Identity	Type	Role / context	Confirmed or suspected impact

Affected assets and services

Asset / service	Identifier	Criticality / role	Evidence of impact

Network, file and cloud indicators

Indicator	Type	Source	Relevance and limitation

5. Observed facts

List facts directly supported by evidence. Number each fact so it can be referenced later.

1.
2.
3.

6. Timeline

Use UTC unless the assignment specifies otherwise. Separate event time from ingest or alert time when relevant.

UTC time	Source	Entity	Observed activity	Evidence reference	Confidence

7. Evidence reviewed

Evidence ID	Source	Collection / query method	Time range	Integrity or quality note	Location / reference
EV-001					

Use the separate evidence log for detailed records.

8. Queries performed

Query ID	Data source	Query / filter	Time range	Result summary	Next pivot
Q-001					

Use the query journal when more detail is required.

9. Analysis

Interpretation

Explain what the combined facts suggest. Connect evidence through identity, time, process, network, session, request, file or resource pivots.

Alternative explanations considered

Alternative	Evidence supporting it	Evidence against it	Status
			Open / unlikely / ruled out

Visibility gaps and limitations

State missing data, parser failures, disconnected sources, clock issues, retention gaps or permissions that limit the conclusion.

10. Classification and confidence

Field	Entry
Classification	False positive / benign positive / suspicious / confirmed incident / insufficient evidence / data-quality issue
Confidence	Low / medium / high
Confidence reasoning	
Potential severity	Informational / low / medium / high / critical, according to assignment definitions
Business or lab impact	

11. Actions and recommendations

Actions already taken

Record only authorised actions actually performed.

1.
2.

Recommended next actions

Priority	Recommendation	Owner / escalation target	Reason	Deadline

Do not claim that a recommendation has been implemented unless evidence confirms it.

12. Escalation decision

Field	Entry
Escalated?	Yes / no
Escalated to	
Time	
Reason	
Information supplied	
Questions requiring higher-tier review	

13. Lessons and detection improvements

- Which field or source was most valuable?
- Which evidence was missing?
- Did the detection title and severity accurately describe the activity?
- What safe tuning, logging or playbook improvement is recommended?
- What should the analyst do differently next time?

14. References and attachments

List approved screenshots, exports, evidence IDs, task instructions and public references. Use repository-relative paths where possible. Redact sensitive values.

15. Reviewer notes

Reviewer	Date	Decision	Required corrections
		Approved / revise	

Source: labs/01-authentication-triage/README.md

Practice Lab 01 — Authentication Failure Chain

Track: SOC Level 1
Difficulty: Beginner → intermediate
Estimated time: 60–90 minutes
Dataset: `sample-logs/authentication/failed-login-chain.ndjson`
Scope: Synthetic `pod-03` training records only

Scenario

A Wazuh alert reports repeated authentication failures involving a service account. A successful login appears later in the same period, but one telemetry source also reports a collection gap.

Your task is to perform a defensible Level 1 triage. Do not assume that the alert proves compromise, and do not ignore the visibility gap.

Learning objectives

You should be able to:

- distinguish normal and suspicious authentication sequences;
- pivot by account, source address, session and correlation identifiers;
- build an event-time timeline;
- identify what the available records prove and what remains uncertain;
- recognise a cross-pod access-control denial without attempting to reproduce it;
- document a telemetry gap and explain its effect on confidence;
- prepare an incident report, evidence log and escalation package.

Safety boundary

- Use only the supplied synthetic dataset or the approved local Wazuh stack.
- Do not send requests to any VCC pod, endpoint or public address as part of this practice lab.
- Reserved example IP addresses in the dataset are documentation values, not targets.
- Do not attempt to change pod scope or access another pod.

Preparation

Study:

1. `docs/secops-foundations/01-security-operations-foundations.md`
2. `docs/secops-foundations/02-alert-triage-evidence-and-escalation.md`
3. `docs/secops-foundations/03-siem-pipelines-and-log-quality.md`
4. The Log Literacy manual sections on time, correlation and evidence statements

Copy these templates into your working folder:

- `templates/incident-report-template.md`
- `templates/evidence-log-template.md`
- `templates/query-journal-template.md`

Part A — Validate the dataset

Before analysing the security activity:

1. Confirm that every non-empty line is valid JSON.
2. Count the records.
3. Identify the schema version and pod identifier.
4. Confirm that each event is marked `synthetic: true`.
5. Compare `event_time` with `ingest_time` for delayed records.
6. Note any event type that represents telemetry health rather than user activity.

Example local validation command:

```
python3 - <<'PY'
import json
from pathlib import Path

path = Path("sample-logs/authentication/failed-login-chain.ndjson")
records = [json.loads(line) for line in path.read_text().splitlines() if line.strip()]
print(f"records={len(records)}")
print(f"pods={sorted({record['pod_id'] for record in records})}")
print(f"schemas={sorted({record['schema_version'] for record in records})}")
print(f"all_synthetic={all(record.get('synthetic') is True for record in records)}")
PY
```

Record this command and result in your query journal.

Part B — Authentication pivots

Answer the following with evidence IDs and exact queries:

1. Which accounts experienced authentication failures?
2. Which source addresses generated failures?
3. How many failures involved `svc-backup`?

4. Did any successful authentication follow those failures?
5. Which session was created by the relevant success?
6. Did the same source target additional accounts?
7. Which later events reference the suspicious session?
8. Is there a normal failure-followed-by-success sequence elsewhere in the dataset? How does its context differ?

You may use Python, `jq`, Wazuh dashboard filters or another approved local tool. Record the exact method.

Part C — Timeline

Build a timeline beginning five minutes before the first relevant failure and ending five minutes after the session revocation.

Your timeline should include:

- authentication failures;
- successful authentication;
- application activity;
- authorization decisions;
- account changes;
- session action;
- telemetry-health events.

Use **event time** for the primary order and note meaningful ingest delay separately.

Part D — Evidence reasoning

Write an evidence statement for each of the following:

1. Repeated failures for the service account.
2. Successful login from the same source.
3. Activity performed through the new session.
4. The denied cross-pod request.
5. The sensitive account change.
6. The process-telemetry gap.

For each statement, include:

- what the record directly proves;
- what it suggests in context;
- what it does not prove;
- the next source that would reduce uncertainty.

Part E — Classification

Choose one current classification:

- false positive;
- benign positive;
- suspicious;
- confirmed synthetic incident;
- insufficient evidence;
- data-quality issue.

Then provide:

- confidence: low, medium or high;
- potential severity;
- the strongest supporting facts;
- alternative explanations considered;
- the effect of the telemetry gap;
- whether the case should be escalated.

The quality of your reasoning matters more than selecting a label without explanation.

Part F — Deliverables

Submit the following through the programme's approved assignment repository when this lab is formally assigned:

```
lab-01-authentication-triage/
├── incident-report.md
├── evidence-log.md
├── query-journal.md
└── screenshots/
    └── README.md
```

The screenshots folder may contain approved Wazuh views, but do not include credentials, private URLs, unrelated alerts or another pod's data.

Review checklist

- [ ] Facts are separated from interpretation.
- [ ] Every important claim cites an evidence ID.
- [ ] Queries include their time ranges and data source.
- [ ] A zero-result search is not treated as proof without checking source health.
- [ ] The cross-pod denial is documented, not reproduced.
- [ ] The telemetry gap is included in the confidence assessment.
- [ ] No secret or private endpoint appears in the submission.
- [ ] The final recommendation stays within SOC Level 1 authority.

Instructor separation

This public repository intentionally contains no hidden answer key or scenario ground truth. Mentor review material belongs in a separate private repository.

Source: references/query-command-reference/README.md

NeoLabs SOC Level 1 Query and Command Reference

Version: 0.2-draft
Review baseline: 1 August 2026
Test scope: Synthetic files, the learner's local Wazuh stack and explicitly authorised VCC data only

> A query is a question expressed in a platform's syntax. Record the exact query, data source, time field and time range so another analyst can reproduce the result.

1. Choose the correct language

Interface or source	Primary syntax	Typical use
Wazuh specialised tabs and server API	Wazuh Query Language (WQL)	Filter agents, rules, decoders, groups and supported API resources
Wazuh/OpenSearch Discover	Dashboard search syntax and field filters	Search indexed alert or archive documents
Wazuh Indexer Dev Tools	OpenSearch Query DSL	Structured Boolean, range, aggregation and exact-field queries
NDJSON/JSON files	`jq` or Python	Validate and analyse synthetic datasets
Plain-text logs	`grep`, `awk`, `sed` with care	Fast local inspection and counting
Linux system journal	`journalctl`	Filter systemd journal by time, unit, priority and fields
Linux audit logs	`ausearch`	Search audit records by event type, key, user, time and success
Windows event logs	PowerShell `Get-WinEvent`	Filter channels, IDs, time windows and structured event properties

Do not mix query languages. A WQL expression is not automatically valid OpenSearch DSL, PowerShell or shell syntax.

Part I — Wazuh Query Language

2. WQL structure

WQL uses:

```
field operator value
```

Operators:

```
=   equal
!=  not equal
>   greater than
<   less than
~   like/matching text
```

Separators:

```
;   AND
,   OR
()  grouping
```

Examples:

```
status=active
status=active;os.name=Ubuntu
status=active,(os.name=Ubuntu,os.name=Debian)
name~web
```

Use double quotes around values containing spaces:

```
name="Windows Server 2025"
```

WQL is case-sensitive. Use the field suggestions and validation provided by the dashboard tab.

3. WQL cautions

- Field availability depends on the selected tab or API endpoint.
- `;` means AND and `,` means OR; this differs from many programming languages.
- The `~` operator is not a regular-expression guarantee. Confirm its behaviour in the specific endpoint.

- When using the API, URL-encode reserved characters or use a client option that performs encoding.
- WQL filters management/API data; indexed security-event searches may use another syntax.

4. WQL investigation record

```
Question: Which active agents report Ubuntu?
Interface: Agents management / supported WQL search
Query: status=active;os.name=Ubuntu
Time run: 2026-08-01 10:00 UTC
Result: [record count and summary]
Limitation: Agent status does not prove current event delivery for every configured source.
```

Part II — Dashboard field filters and Discover

5. Build searches from fields

In Discover or Threat Hunting:

1. select the correct data view, such as `wazuh-alerts-*`;
2. set an absolute time range;
3. inspect an event to confirm field names;
4. add include/exclude filters from field values;
5. display only useful columns;
6. sort by the relevant event timestamp;
7. record every inherited filter.

Useful VCC fields include:

```
pod_id
event_type
action
outcome
user
source_ip
session_id
correlation_id
event_id
schema_version
synthetic
```

Field paths can be nested or prefixed after Wazuh indexing. Inspect the actual event rather than assuming the path.

6. Exact versus analysed fields

Search engines may store a text field in two forms:

- analysed text, useful for word searching;
- keyword/exact value, useful for equality, grouping and aggregation.

If `user` searches return unexpected partial matches, inspect whether an exact/keyword form exists. Do not invent a `.keyword` suffix without checking the mapping.

7. Time-range discipline

Record:

- start and end in UTC;
- the dashboard time field;
- browser time-zone setting;
- whether the source also has `event_time` or `ingest_time`;
- any known delay or clock skew.

A relative range such as “last 15 minutes” is not reproducible later.

Part III — OpenSearch Query DSL

8. Basic exact query

Use Dev Tools only in an authorised local environment and only against approved indices.

```
GET wazuh-alerts-*/_search
{
  "size": 50,
  "query": {
    "term": {
      "data.pod_id": "pod-03"
    }
  },
  "sort": [
    { "timestamp": "asc" }
  ]
}
```

A `term` query expects an exact value and is normally appropriate for keyword-like fields. Confirm the mapping first.

9. Boolean filter

```
GET wazuh-alerts-*/_search
{
  "size": 100,
  "query": {
    "bool": {
      "filter": [
        { "term": { "data.pod_id": "pod-03" } },
        { "term": { "data.event_type": "authentication" } },
        { "term": { "data.user": "svc-backup" } },
        {
          "range": {
            "timestamp": {
              "gte": "2026-08-01T09:00:00Z",
              "lte": "2026-08-01T09:30:00Z"
            }
          }
        }
      ]
    }
  },
  "sort": [
    { "timestamp": "asc" }
  ]
}
```

Use `filter` for exact constraints that do not need relevance scoring.

10. Search one source across accounts

```
GET wazuh-alerts-*/_search
{
  "size": 100,
  "query": {
    "bool": {
      "filter": [
        { "term": { "data.pod_id": "pod-03" } },
        { "term": { "data.source_ip": "203.0.113.44" } },
        {
          "range": {
            "timestamp": {
              "gte": "2026-08-01T09:00:00Z",
              "lte": "2026-08-01T09:30:00Z"
            }
          }
        }
      ]
    }
  },
  "sort": [
    { "timestamp": "asc" }
  ]
}
```

11. Count by account

```
GET wazuh-alerts-*/_search
{
  "size": 0,
  "query": {
    "bool": {
      "filter": [
        { "term": { "data.pod_id": "pod-03" } },
        { "term": { "data.event_type": "authentication" } },
        { "term": { "data.outcome": "failure" } },
        {
          "range": {
            "timestamp": {
              "gte": "2026-08-01T09:00:00Z",
              "lte": "2026-08-01T09:30:00Z"
            }
          }
        }
      ]
    }
  },
  "aggs": {
    "failures_by_user": {
      "terms": {
        "field": "data.user",
        "size": 20
      }
    }
  }
}
```

If the aggregation fails, verify that the field is aggregatable and mapped as an exact/keyword value.

12. Check field mappings

```
GET wazuh-alerts-*/_mapping/field/data.user
```

Use mappings to confirm type and exact-field behaviour. Do not change production mappings from a student lab.

13. Query DSL cautions

- `match` performs analysed full-text search and is not the same as `term`.
- Wildcards at the beginning of a value can be expensive.
- Large `size` values can overload the browser or indexer.
- Aggregation counts can be misleading when duplicate events exist.
- The `_source` document may contain sensitive fields; export only what the assignment requires.
- A successful query proves only that matching indexed documents were found.

Part IV — jq for NDJSON and JSON

14. Validate every NDJSON line

```
jq -c . sample-logs/authentication/failed-login-chain.ndjson >/dev/null
```

No output and exit code `0` means each non-empty line was valid JSON. It does not validate the event schema.

15. Display selected fields

```
jq -c '{event_time,event_id,event_type,user,source_ip,outcome,session_id}' \
  sample-logs/authentication/failed-login-chain.ndjson
```

16. Filter authentication failures

```
jq -c 'select(.event_type == "authentication" and .outcome == "failure")' \
  sample-logs/authentication/failed-login-chain.ndjson
```

17. Filter by account and sort by time

For NDJSON, first read the stream into an array:

```
jq -s '
  map(select(.user == "svc-backup"))
  | sort_by(.event_time)
  | .[]
  | {event_time,event_id,action,outcome,source_ip,session_id}
' sample-logs/authentication/failed-login-chain.ndjson
```

Use `-s` carefully with large files because it loads all records into memory.

18. Count failures by user

```
jq -s '
  map(select(.event_type == "authentication" and .outcome == "failure"))
  | group_by(.user)
  | map({user: .[0].user, count: length})
' sample-logs/authentication/failed-login-chain.ndjson
```

`group_by` expects sorted input by the grouping expression. jq sorts as part of `group_by`, but review output rather than assuming every missing user field behaves as intended.

19. Find duplicate event IDs

```
jq -r '.event_id' sample-logs/authentication/failed-login-chain.ndjson \
  | sort \
  | uniq -d
```

No output means no duplicate IDs were found in the examined file. It does not prove upstream collectors never duplicated semantically identical events under different IDs.

20. Check pod and synthetic markers

```
jq -s '{
  pods: (map(.pod_id) | unique),
  schemas: (map(.schema_version) | unique),
  all_synthetic: all(.[]; .synthetic == true)
}' sample-logs/authentication/failed-login-chain.ndjson
```

Part V — grep, awk and text logs

21. Fixed-string search

Prefer fixed-string mode when you do not need regular expressions:

```
grep -F 'Failed password' sample.log
```

22. Include line numbers and context

```
grep -n -C 2 -F '203.0.113.44' sample.log
```

23. Count matching lines

```
grep -c -F 'authentication failure' sample.log
```

Line count is not automatically event count. Multiline events and duplicate records can change the meaning.

24. Safe recursive search

```
grep -RIn --exclude='*.key' --exclude='.env' -F 'correlation-id' ./approved-log-folder
```

Run recursive searches only inside the authorised local working directory. Avoid accidentally scanning credential folders or unrelated personal files.

25. awk field example

For a controlled space-delimited sample:

```
awk '$9 == 401 {print $1, $4, $7, $9}' access.log
```

Real web log fields can contain quoted spaces and custom formats. `awk` column assumptions must be verified against the exact log format.

Part VI — journalctl

26. Query by unit and time

```
journalctl --unit=sshd.service \
  --since='2026-08-01 09:00:00 UTC' \
  --until='2026-08-01 10:00:00 UTC' \
  --no-pager
```

27. Query by priority

```
journalctl --priority=warning..alert --since='1 hour ago' --no-pager
```

28. Output JSON

```
journalctl --unit=sshd.service --since='today' --output=json --no-pager \
  | jq -c '{time:.__REALTIME_TIMESTAMP,unit:._SYSTEMD_UNIT,pid:._PID,message:.MESSAGE}'
```

`__REALTIME_TIMESTAMP` is normally expressed in microseconds since the Unix epoch. Convert carefully before mixing it with ISO 8601 timestamps.

29. Filter structured journal fields

```
journalctl _SYSTEMD_UNIT=ssh.service _COMM=sshd --since='today' --no-pager
```

Unit names differ between distributions. Confirm whether the system uses `ssh.service` or `sshd.service`.

30. journalctl cautions

- Access may require elevated local permissions.
- Volatile journals can disappear after reboot.

- Retention depends on journal configuration and storage.
- Service messages are application text inside a structured journal; parse them cautiously.
- A missing record may mean the unit did not log it, not that the action did not happen.

Part VII — ausearch

31. Failed login records

```
ausearch --message USER_LOGIN --success no --start today --interpret
```

32. Search by audit key

```
ausearch --key identity_changes --start today --interpret
```

The audit key exists only when an audit rule was configured with that key.

33. Unsuccessful system calls

```
ausearch --message SYSCALL --success no --start today --interpret
```

This can produce high volume. Narrow by time, user, executable or audit key where appropriate.

34. ausearch cautions

- Audit records for one action can span multiple related messages with the same audit event identifier.
- `--interpret` improves readability but may resolve numeric values using current system state.
- Audit rules must exist before the activity occurs.
- Use elevated permissions only on a system you own or are authorised to administer.

Part VIII — PowerShell and Windows Event Logs

35. List recent failed logons

```
$start = [datetime]'2026-08-01T09:00:00Z'
$end   = [datetime]'2026-08-01T10:00:00Z'

Get-WinEvent -FilterHashtable @{
    LogName   = 'Security'
    Id        = 4625
    StartTime = $start.ToLocalTime()
    EndTime   = $end.ToLocalTime()
} | Select-Object TimeCreated, Id, MachineName, RecordId
```

`Get-WinEvent` uses local `DateTime` values for the filter. Record how UTC times were converted.

36. Inspect structured event properties

```
$event = Get-WinEvent -FilterHashtable @{
    LogName = 'Security'
    Id      = 4625
} -MaxEvents 1

[xml]$xml = $event.ToXml()
$xml.Event.EventData.Data | ForEach-Object {
    [pscustomobject]@{
        Name  = $_.Name
        Value = $_.'#text'
    }
}
```

Property positions can differ between event versions. Named XML fields are safer than relying only on numeric property indexes.

37. Sysmon process creation

```
Get-WinEvent -FilterHashtable @{
    LogName   = 'Microsoft-Windows-Sysmon/Operational'
    Id        = 1
    StartTime = (Get-Date).AddHours(-1)
} | Select-Object TimeCreated, Id, RecordId, Message
```

The message is convenient for reading, but structured XML fields such as `ProcessGuid`, `Image`, `CommandLine`, `ParentProcessGuid` and hashes are stronger for correlation.

38. Export selected events

```
Get-WinEvent -FilterHashtable @{
    LogName = 'Microsoft-Windows-Sysmon/Operational'
    Id      = 1,3,22
} -MaxEvents 200 |
    Export-Csv -Path '.\approved-output\sysmon-review.csv' -NoTypeInformation
```

Before sharing, review exported command lines, user names, paths and addresses for sensitive information.

39. Windows event cautions

- Event 4624 proves a logon session was created, not that it was authorised.
- Event 4625 proves a logon attempt failed, not why the attempt occurred.
- Event 4688 command-line visibility depends on audit policy.
- Sysmon coverage depends on its installed version and configuration.
- Event messages can be localised; structured fields are more portable.
- Clearing or overwriting a log creates visibility limitations that must be documented.

Part IX — Query-writing method

40. Ten questions before drawing a conclusion

1. Which source produced the record?
2. Which time field am I using?
3. Which identity acted or was targeted?
4. Which asset, object or service was affected?
5. What action and outcome are recorded?
6. Which fields are original, decoded or enriched?
7. What preceding and following events matter?
8. What normal behaviour or maintenance context exists?
9. What does this result fail to prove?
10. Which next query would reduce uncertainty most?

41. Query journal standard

Every important query should record:

```
Question being tested:
Platform and source:
Exact query:
Time field:
Absolute UTC range:
Result count:
Important result:
Negative finding:
Evidence IDs:
Limitations:
Next pivot:
```

42. Common query mistakes

- using free text when an exact structured field exists;
- searching ingest time while interpreting the result as event time;
- leaving a hidden dashboard filter active;
- using `match` when exact equality is required;
- grouping duplicate events without checking IDs;
- treating zero results as proof before validating the source;
- pasting secrets or private URLs into commands, screenshots or reports;
- running commands outside the approved local or VCC scope;
- copying a query from another SIEM without translating field names and semantics.

Authoritative references

- Wazuh, *Filtering data using Wazuh Query Language*.
- Wazuh, *Wazuh indexer indices* and *Event logging*.
- OpenSearch, *Query DSL* and mapping documentation.
- jq manual.
- GNU grep and GNU awk manuals.
- systemd `journalctl` manual.
- Red Hat audit and `ausearch` documentation.
- Microsoft Learn, `Get-WinEvent`, Windows auditing and Sysmon documentation.
- `research/AUTHORITATIVE_SOURCE_REGISTER.md`.